CASE STUDY

Healthcare Threat Actor Watchlist, 2023 to 2026: Who Hits Hospitals, How They Get In, and What the Record Says

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

People who keep hospitals, clinics, pathology labs, dialysis centers and the billing companies behind them running have had four hard years. The HHS Office for Civil Rights breach portal, which lists breaches of unsecured protected health information affecting 500 or more individuals that HIPAA covered entities and business associates report to HHS, holds 745 reports submitted in 2023, 741 in 2024, 810 in 2025 and 618 in 2026 through 9 October, covering about 702 million individual records in total [1] (**Confirmed** for the per-year counts, which this study derived from the portal's exports; the total is this study's sum). One entry dominates: Change Healthcare, at 192,700,000 individuals [1]. That attack has its own study, The Change Healthcare Attack of 2024, and this one summarizes it in a paragraph.

This study is a watchlist: the ransomware operations and state-linked groups that US and UK agencies, victims and threat-intelligence teams have tied to healthcare, what each one does, and what the record says to do about them. The joint FBI, CISA and HHS advisories carry most of the weight. After a December 2023 law-enforcement action, an ALPHV Blackcat administrator urged affiliates to target hospitals, and healthcare became the sector hit most often among about 70 leaked victims [13] (**Confirmed**). North Korea's Andariel unit funds espionage through ransomware against US healthcare, and one of its alleged members is wanted on a federal warrant from Kansas [24] [31] (**Confirmed**). An Iran-associated group, Pioneer Kitten, works with ransomware affiliates, and its victims include healthcare facilities [25] (**Confirmed**).

The way in is rarely new malware. Across the 2023 to 2026 advisories, healthcare-relevant intrusions start with stolen or phished credentials on VPNs without multi-factor authentication, help-desk and phone social

engineering, and exploited edge devices and remote-access tools [14] [18] [20] [22] (**Confirmed** per advisory; the pattern is **Inferred**). The eleven healthcare-relevant advisories name 130 live ATT&CK techniques; data encryption for impact appears in eight of them, and PowerShell, public-facing exploits and remote access tools in seven (Part 6, **Inferred**: this study's count). Of the 76 CVEs those advisories and the Play advisory name, 61 are in CISA's Known Exploited Vulnerabilities catalog [82] (**Confirmed**), and most are edge and remote-access products (**Inferred**).

> Evidence grade: incident facts, counts, advisories, enforcement actions and court records are **Confirmed** from government, victim and vendor primaries opened on 3 November 2026. A group is named for an event only where an opened primary names it; several widely repeated attributions are marked "not checked" because their primaries could not be opened. Survey figures that a vendor page relays from other sources are **Reported**.

Key facts at a glance

Field	Value
Period	January 2023 to 3 November 2026, with baselines from 2015 (Orangeworm), 2021 (Maui) and 2022 (Daixin Team)
HHS breach reports, 500+ individuals, by submission year	2023: 745 (183,256,225 individuals); 2024: 741 (290,052,596); 2025: 810 (141,248,514); 2026 to 9 Oct: 618 (87,693,355) [1]
Largest single entries	Change Healthcare 192,700,000 (2024) [1]; Conduent Business Services 62,224,658 (2025) [1] [10]; DentaQuest 15,000,000 (2026) [1] [11]
Share of each year carried by its largest entry	Change about 66% of 2024; Conduent about 44% of 2025; DentaQuest about 17% of 2026 to date (this study's arithmetic on [1])
Healthcare complaints to the FBI in 2024	238 ransomware and 206 data breach complaints from the Healthcare and Public Health sector, the most data breach complaints of any critical infrastructure sector [37]
Healthcare-relevant joint advisories bound here	11: ALPHV, Black Basta, Rhysida, RansomHub, Interlock, Andariel, Maui, Medusa, Akira, LockBit, Pioneer Kitten [13] to [20] [23] to [25]
Techniques those advisories name	130 live ATT&CK v20 Enterprise techniques; T1486 Data Encrypted for Impact in 8 of 11 (Part 6)
CVEs those advisories and the Play advisory name	76 distinct, 61 in KEV at catalog 2026.11.03 [82]
State-linked actors on the list	North Korea: Andariel (Maui ransomware) and Moonstone Sleet (has deployed Qilin) [23] [24] [43]; Iran: Pioneer Kitten, whose ransomware side the FBI judges likely not sanctioned [25]
Charges and sanctions	LockBitSupp named as Dmitry Khoroshev, sanctioned by the UK, US and Australia on 7 May 2024 [33]; Rim Jong Hyok, federal warrant 24 July 2024, reward up to $10 million [31] [32]
HIPAA Security Rule update	Proposed 6 January 2025 [53]; the current Unified Agenda moves final action to July 2027 [56]
ATT&CK record bound here	12 groups, 15 software objects, 130 techniques, one Navigator layer (Part 6)

Key findings

- **Hospitals became a stated target in December 2023.** The ALPHV advisory update of 27 February 2024 links the shift to the group's administrator urging affiliates to target hospitals after the law-enforcement action, and says healthcare was "the most commonly victimized" sector since mid-December [13] (**Confirmed**).
- **The biggest numbers come from vendors, the worst disruption from providers.** In every year of the window, several of the largest HHS entries are business associates and vendors: Welltok, Perry Johnson & Associates and Managed Care of North America in 2023; Conduent and Episource in 2025; Aesto, TriZetto and CareCloud in 2026 (Lumexa's breach was in a vendor's system) [1] [9] [10] [12], while the provider outages at Ascension, Synnovis, Kettering Health and DaVita carry smaller counts but disrupted operations, and at Synnovis and Kettering Health stopped services [3] [4] [6] [8] (**Inferred** from **Confirmed**

entries; DaVita says patient care continued).

- **Victims rarely name the group.** Of the provider notices opened here, only Kettering Health names its attacker (Interlock) [6] [7]. The Ascension letter, the DaVita 8-K, the Prospect Medical notice and the Synnovis site name no group [3] [4] [5] [8] (**Confirmed**).
- **Identity is the front door.** Help-desk impersonation, voice phishing, MFA fatigue and VPN logins without MFA recur in the Scattered Spider, ALPHV, Black Basta, Rhysida and Akira advisories [13] [14] [18] [20] [22], and in Microsoft's review of hospital incidents [36] (**Confirmed**).
- **Edge devices and remote tools are the side door.** The KEV-joined CVE list is led by Netlogon, NetScaler, FortiOS, Remote Desktop Services, Log4j2, GoAnywhere, ActiveMQ, FortiClient EMS and ScreenConnect [82] (**Confirmed**). Medusa often exploits new flaws within 24 hours of disclosure [16] (**Confirmed**).
- **North Korea uses healthcare ransom to pay for spying.** Andariel of the Reconnaissance General Bureau's 3rd Bureau funds espionage through ransomware against US healthcare entities [24]; the Maui advisory describes encryption of servers for health records, diagnostics and imaging [23] (**Confirmed**).
- **Extortion no longer needs encryption.** Some ALPHV affiliates and Scattered Spider extort with stolen data alone [13] [22]; one Medusa victim was contacted by a second actor demanding a second payment [16] (**Confirmed**).
- **Medical devices are part of the surface.** CISA found an embedded backdoor in all three Contec CMS8000 patient-monitor firmware versions it examined, and the FDA advised running the monitors unplugged from the network [38] [39] (**Confirmed**).
- **Regulation is slower than the threat.** The HHS goals are voluntary [50], the proposed HIPAA Security Rule update now targets final action in July 2027 [56], and none of the healthcare cyber bills opened here was found enacted (2025 bills' later actions not checked) [77] to [81] (**Confirmed** for each document; that a final rule and a law are both absent is **Inferred** from their stages).

Top recommendations

1. **Put phishing-resistant MFA on every remote path first.** VPNs, remote gateways, webmail and admin accounts. VPN access without MFA is among the stated ways in for Rhysida, Akira and Daixin Team and in Microsoft's hospital cases [18] [20] [30] [36]; the ALPHV advisory recommends FIDO/WebAuthn or PKI-based MFA [13].
2. **Make the help desk verify callers.** Scattered Spider and ALPHV affiliates call help desks or staff posing as IT to reset passwords and move MFA [13] [22]. Require out-of-band verification for any reset or MFA change (**Inferred** from the advisories).
3. **Patch internet-facing KEV entries before anything else, and assume compromise when you patch late.** The advisories repeat this first [16]; the Pioneer Kitten advisory warns that patching an exploited edge device does not remove an intruder already inside [25].
4. **Allowlist remote access software.** ScreenConnect, AnyDesk, Quick Assist and Splashtop are abused by Black Basta and ALPHV affiliates [13] [14], and the ALPHV advisory calls for allowlisting remote access tools [13].
5. **Protect the backups and the hypervisors.** Keep offline, immutable, tested backups [16]. ALPHV, Akira and DragonForce encrypt VMware, ESXi and Nutanix AHV hosts [13] [20] [22].

6. **Hold vendors to the same bar.** Business associates carry the largest breach of 2025 and several of the largest of 2023 and 2026 [1] (**Inferred** from the entity types in the export); the HHS goals include vendor requirements and third-party incident reporting [50], and the 44-attorney-general Labcorp settlement included vendor risk management terms [76].
7. **Inventory and segment medical devices.** Monitor IoT devices, encrypt PHI and segment networks as the Maui advisory sets out [23]; follow the FDA's handling advice for monitors like the Contec CMS8000 [39].
8. **Use the HPH Cybersecurity Performance Goals as the baseline.** HHS co-authored advisories point the sector to them [17] [50], and HIPAA penalties consider recognized security practices under Public Law 116-321 [59].

Scope and method

This study covers threat actors and events that touched healthcare from January 2023 to 3 November 2026: ransomware and extortion groups, state-linked groups, the incidents with the largest counts or the worst care disruption, the government and regulatory response, and the defender view. It reaches back to 2015, 2021 and 2022 for three baselines. It follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them. Every source in the Sources table was opened on 3 November 2026. Direct quotations are kept under 15 words, and tradecraft is described at the level the advisories use (technique names and ids), never as commands or payloads.

Other studies are the home for some events. Change Healthcare belongs to The Change Healthcare Attack of 2024, the MOVEit wave to The Cl0p MOVEit Breach, Log4j2 to Log4Shell, Pioneer Kitten's full record to Iran-Attributed Threat Actors: The Public Record, Andariel's to Other State-Linked Threat Actors: The Public Record and North Korea-Attributed Threat Actors: The Public Record, and the Russia-linked and China-linked healthcare threads to Russia-Attributed Threat Actors: The Public Record and China-Attributed Threat Actors: The Public Record. This study summarizes each in a paragraph or a table row and links.

How the numbers were made:

- **Breach counts.** The per-year counts come from the HHS portal's two CSV exports (Under Investigation and Archive), bucketed by submission year [1]. The portal lists only breaches of 500 or more individuals, OCR updates entries over time, and individuals are summed per report, so the same person can be counted more than once (**Inferred**). The 2026 figure runs to 9 October, the latest submission in the export.
- **Attribution.** A group is named for an event only where a primary opened for this study names it. Attributions that are widely repeated but whose primaries could not be opened (for example Qilin for Synnovis) are marked "not checked".
- **Healthcare-relevant advisories.** Eleven joint advisories qualify because they name the Healthcare and Public Health (HPH) sector as a victim or carry HHS as an author or co-sealer: ALPHV Blackcat [13], Black Basta [14], RansomHub [15], Medusa [16], Interlock [17], Rhysida [18], LockBit [19], Akira [20], Maui [23], Andariel [24] and Pioneer Kitten [25]. The Play and Scattered Spider advisories [27] [22] are used for tradecraft but not counted in the technique figures, because neither names healthcare; the CVE join in Part 5.4 does include the Play advisory.

- **Technique counts.** Technique ids were taken from each advisory's own mapping tables, checked against the library's ATT&CK v20.0 data, and revoked ids mapped to their successors through `data/attack/superseded_by.jsonl` [83]. Mobile-domain ids and the Maui advisory's T1059.008 tag are left out (Part 6.3). The ALPHV advisory page links only the five ids of its February 2024 update, so ALPHV is undercounted [13].

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the victim's own notice or filing, a government agency, a court or regulator, a data feed from its publisher, or the MITRE page itself
Reported	Stated only in a secondary source relaying another party; the original was not opened
Demonstrated	Not used in this study
Inferred	This study's own reasoning or arithmetic from Confirmed facts, labelled as such

Part 1: the incident record

1.1 The breach count by year

Submission year	Reports (500+)	Individuals (sum)	Large entries named in this study	Sources
2023	745	183,256,225	Welltok 14,782,887; HCA Healthcare 11,270,000; Perry Johnson & Associates 9,302,588 (ransomware); Maximus 9,179,390; Managed Care of North America 8,627,242 (ransomware); Delta Dental of California 7,056,189; Norton Healthcare 2.5 million (ransomware)	[1]
2024	741	290,052,596	Change Healthcare 192,700,000; Ascension Health 5,466,931; Lurie Children's 775,860	[1]
2025	810	141,248,514	Conduent 62,224,658; Aflac 13,924,906; Episource 6,725,572; Yale New Haven 5,556,702; Blue Shield of California 4,700,000 (an analytics misconfiguration, not an intrusion); PIH Health 2,947,264; DaVita 2,689,826	[1]
2026 to 9 Oct	618	87,693,355	DentaQuest 15,000,000; Aesto 9,540,683; iRhythm 8,179,772; Lumexa Imaging 5,830,949; AdaptHealth 4,115,802	[1]

The counts are this study's derivation from the exports and move as OCR updates entries [1] (**Confirmed** as of 3 November 2026). The Conduent entry is given as the current OCR figure on 3 November 2026; OCR updates entries, so re-check it before citing [1].

1.2 Timeline

Dates are the event date where a primary gives one, otherwise the publication or submission date. "Group named" lists only a group an opened primary names for that event.

Date	Event	What the record shows	Group named	Sources	Grade
Since May 2021; advisory 2022-07-06	Maui ransomware against HPH (baseline)	FBI assesses North Korean state-sponsored actors encrypted servers for health records, diagnostics, imaging and intranet services	North Korean state-sponsored actors	[23]	Confirmed

Date	Event	What the record shows	Group named	Sources	Grade
2022-10-21	Daixin Team advisory (baseline)	Access through an unpatched VPN server and phished credentials on a legacy VPN without MFA; health record, diagnostics and imaging servers encrypted; PHI stolen and extorted	Daixin Team	[30]	Confirmed
2023-05-27	MOVEit Transfer exploitation begins	CL0P (also known as TA505) exploits CVE-2023-34362; home study CL0P_FILE_TRANSFER_2023	CL0P	[28]	Confirmed
2023-06-14	LockBit advisory	About 1,700 US attacks and about $91M in US ransoms since January 2020; HPH among sectors hit	LockBit	[19]	Confirmed
2023-07-31 to 2023-08-03	Prospect Medical Holdings	IT systems disrupted; HHS records a "ransomware incident" affecting 1,309,096 people	none	[5] [1]	Confirmed
2023	Large HHS entries of the year	Welltok, HCA Healthcare, Perry Johnson & Associates, Maximus, Managed Care of North America, Delta Dental of California, Norton Healthcare (Part 1.1)	none in the entries	[1]	Confirmed
2023-11-15	Rhysida advisory	Deployed since May 2023 against education, healthcare, manufacturing, IT and government "targets of opportunity"	Rhysida	[18]	Confirmed
2023-11-16	Scattered Spider advisory	Help-desk impersonation, MFA fatigue, SIM swaps; updated 2025-07-29 to add DragonForce; no healthcare focus	Scattered Spider	[22]	Confirmed
2023-11-17	CISA HPH Sector Mitigation Guide	Companion to the July 2023 HPH Cyber Risk Summary	n/a	[60] [61]	Confirmed
2023-12-19; updated 2024-02-27	ALPHV Blackcat advisory	Administrator urged affiliates to target hospitals after the December 2023 action; healthcare most victimized among about 70 leaked victims	ALPHV	[13]	Confirmed
2024-01-26 to 2024-01-31	Ann & Robert H. Lurie Children's Hospital of Chicago	HHS records a "cyberattack" affecting 775,860 people; names, SSNs, diagnoses, lab results and medications involved	none	[1] [2]	Confirmed
February 2024	Change Healthcare	Largest HHS entry on record, 192,700,000; home study CHANGE_HEALTHCARE_2024 (Part 1.3)	see home study	[1] [34] [69]	Confirmed
2024-02-29	Phobos advisory	RaaS seen since May 2019; public healthcare among targets	Phobos	[26]	Confirmed
2024-04-18	Akira advisory	HPH among preferred sectors; updated 2025-11-13 with about $244.17M claimed	Akira	[20]	Confirmed

Date	Event	What the record shows	Group named	Sources	Grade
2024-05-07	NCA unmasks LockBitSupp	Dmitry Khoroshev named, sanctioned and indicted; LockBit attacks targeted over 100 hospitals and healthcare companies	LockBit	[33]	Confirmed
2024-05-07 and 2024-05-08	Ascension	Files copied; activity detected 2024-05-08 "resulting from a ransomware attack"; HHS 5,466,931 people	none	[3] [1]	Confirmed
2024-05-10; revised 2024-11-08	Black Basta advisory	Over 500 organizations; healthcare called an attractive target; email bombing and Teams social engineering added in November	Black Basta	[14]	Confirmed
2024-06-03	Synnovis (London pathology)	Ransomware hit almost all its IT systems and disrupted pathology services; stolen data published 2024-06-20	none (Qilin: not checked)	[4]	Confirmed
2024-07-24	Rim Jong Hyok warrant	District of Kansas; conspiring to hack and launder money through Maui intrusions against US hospitals	Andariel (RGB)	[31] [32]	Confirmed
2024-07-25	Andariel advisory	RGB 3rd Bureau funds espionage through ransomware against US healthcare	Andariel	[24]	Confirmed
2024-08-07	Royal rebranded as BlackSuit	Advisory update; demands typically $1M to $10M, over $500M in total	Royal / BlackSuit	[21]	Confirmed
2024-08-28	Pioneer Kitten advisory	Iran-associated group partnering with ALPHV, NoEscape and RansomHouse affiliates; healthcare facilities among victims	Pioneer Kitten	[25]	Confirmed
2024-08-29	RansomHub advisory	At least 210 victims since February 2024, HPH among sectors; HHS co-author	RansomHub	[15]	Confirmed
2024-09-26	Storm-0501	Microsoft says the group was recently observed targeting US hospitals	Storm-0501	[35]	Confirmed
2024-10-21 to 2025-01-13	Conduent Business Services	Unauthorized access to a back-office services business associate; HHS 62,224,658 people	none	[10] [1]	Confirmed
2025-01-27 to 2025-02-06	Episource	A criminal saw and copied data; HHS 6,725,572 people	none	[9] [1]	Confirmed
2025-01-30	Contec CMS8000 backdoor	CISA finds an embedded backdoor in patient-monitor firmware; FDA safety communication	n/a	[38] [39]	Confirmed
2025-02-19	Ghost (Cring) advisory	Healthcare named; outdated public-facing software exploited	Ghost	[29]	Confirmed
2025-03-12; updated 2026-08-18	Medusa advisory	Over 500 victims as of April 2026; HPH a frequent victim; HHS co-sealer added	Medusa	[16]	Confirmed

Date	Event	What the record shows	Group named	Sources	Grade
Submitted 2025-04-11	Yale New Haven Health System	Hacking incident, 5,556,702 people	none in the entry	[1]	Confirmed
2025-04-12	DaVita	Ransomware encrypted certain elements of its network; patient care continued; HHS 2,689,826 people	none	[8] [1]	Confirmed
2025-04-09 to 2025-05-20	Kettering Health	System-wide outage from 2025-05-20; elective procedures cancelled; Epic back 2025-06-02; HHS 1,695,382 people	Interlock (by Kettering)	[84] [6] [7] [1]	Confirmed
2025-07-22	Interlock advisory	First seen late September 2024; drive-by and ClickFix initial access; HPH guidance appended	Interlock	[17]	Confirmed
2025	Other large entries	Aflac, PIH Health, Anne Arundel Dermatology, Frederick Health, McLaren Health Care; Blue Shield of California was a misconfiguration	none in the entries	[1]	Confirmed
2025-12-02 and 2025-12-18	Aesto, LLC	Business associate; HHS 9,540,683 people	none in the entry	[2] [1]	Confirmed
2026-03-31 to 2026-04-09	Lumexa Imaging	Documents taken from a vendor's system; HHS 5,830,949 people	none	[12] [1]	Confirmed
2026-05-17 to 2026-05-20	DentaQuest	Data accessed and later posted on the internet; HHS 15,000,000 people, the largest 2026 entry	none	[11] [1]	Confirmed
2026-06-03 to 2026-06-08	iRhythm Technologies	HHS 8,179,772 people	none in the entry	[2] [1]	Confirmed
2026	Other large entries	AdaptHealth, Unlimited Technology Systems, CareCloud, TriZetto Provider Solutions, QualDerm Partners, Baylor Genetics, NYC Health and Hospitals (1,800,000)	none in the entries	[1]	Confirmed
2026-08-18	Medusa advisory update	Uses ATT&CK v20 ids; HHS added as co-sealer	Medusa	[16]	Confirmed

1.3 Change Healthcare, in one paragraph

Change Healthcare, a business associate, is the largest entry the HHS portal holds: 192,700,000 individuals, submitted on 19 July 2024 [1] (**Confirmed**). OCR opened investigations of Change and UnitedHealth Group by Dear Colleague letter on 13 March 2024; Change then filed a 500-person placeholder report and raised the figure to about 100 million notices (22 October 2024), about 190 million (24 January 2025) and about 192.7 million (31 July 2025) [69] (**Confirmed**). UnitedHealth Group said 22 screenshots allegedly from exfiltrated files were posted on the dark web for about a week [34] (**Confirmed**). Nebraska's attorney general sued Change in December 2024, and the court let the case proceed in November 2025, noting nearly 900,000 Nebraskans exposed [73] [74] (**Confirmed**). Microsoft describes the effect as 80% of providers and pharmacies unable to verify insurance or process claims, a figure it cites from others [36] (**Reported**). The attack, the attribution and the tradecraft are covered in The Change Healthcare Attack of 2024.

1.4 Provider outages and vendor breaches are different problems

Two kinds of event fill the record (**Inferred** from the **Confirmed** entries above). Provider outages disrupt care: Kettering Health cancelled elective procedures and diverted emergency patients for about a week [6]; Synnovis lost almost all its IT systems and needed until late autumn 2024 to restore services [4]; Ascension reported a ransomware attack, and DaVita said ransomware encrypted parts of its network and affected some operations while patient care continued [3] [8]. Their individual counts are in the low millions. Vendor breaches carry the counts: Conduent at 62 million, Aesto at 9.5 million, Episource at 6.7 million, Lumexa's vendor at 5.8 million, and TriZetto and CareCloud above 3 million each [1]. A hospital's own controls do little about the second kind (**Inferred**), and vendor requirements are one of the ten Essential HPH goals [50].

1.5 What victims say, and what they leave out

Victim notices are precise about dates and data, and quiet about attackers. Ascension's letter lists medical, payment, insurance and government-ID data categories and the two days files were copied [3]. Synnovis completed its notifications to the data controllers by the end of November 2025 and published no individual count [4]. Kettering Health is the exception: its 5 June 2025 statement and its FAQ attribute the attack to Interlock, based on its investigation, and decline to say whether a ransom was paid [6] [7] (**Confirmed**). The Yale New Haven entry carries no group, and its own notice could not be opened [1].

Part 2: the watchlist

2.1 The list

Actor	ATT&CK objects	Model or sponsor	Healthcare evidence	Latest dated record opened	Sources
ALPHV / BlackCat	S1068	RaaS, Rust, first seen November 2021	Healthcare most victimized after the administrator's call to target hospitals	Advisory update 2024-02-27	[13] [40]
LockBit	S1199, S1202	RaaS since January 2020	Over 100 hospitals and healthcare companies targeted, per the NCA	NCA, 2024-05-07	[19] [33]
Black Basta	S1070	RaaS since April 2022; operators may include current or former Conti members	Advisory calls healthcare an attractive target	Advisory revision 2024-11-08	[14] [42]
RansomHub	S1212	Double-extortion RaaS since February 2024, formerly Cyclops and Knight	HPH among sectors of at least 210 victims	Advisory 2024-08-29	[15] [41]
Medusa	G1051, S1244	Closed group from June 2021, affiliate model by early 2023	HPH a frequent victim; over 500 victims	Advisory update 2026-08-18	[16] [46]
Akira	G1024, S1129, S1194	Ransomware since March 2023	HPH among preferred sectors	Advisory update 2025-11-13	[20]
Qilin (Agenda)	S1242; operator G1050	RaaS since at least 2022, run by Water Galura; North Korea's Moonstone Sleet has deployed it	ATT&CK lists healthcare among main victim sectors	ATT&CK page modified 2026-04-23	[43] [44]
Interlock	none in ATT&CK	Financially motivated, opportunistic, double extortion	Kettering Health names it; HHS co-authored the advisory	Advisory 2025-07-22	[17] [6]
Rhysida	none in ATT&CK	RaaS since May 2023; similarities to Vice Society reported	Healthcare among targets of opportunity	Advisory IOCs revised 2025-04-30	[18]
Royal / BlackSuit	S1073 (Royal only)	Royal from about September 2022, rebranded as BlackSuit	HPH in the sector tags	Advisory update 2024-08-07	[21]
Play	G1040, S1162	Presumed closed group since June 2022	ATT&CK lists healthcare; the advisory does not	Advisory update 2025-06-04	[27] [83]
INC Ransom	G1032, S1139	Active since July 2023	Industrial, healthcare and education targets in the US and Europe	ATT&CK group record	[47]
Storm-0501	G1053, S1247 Embargo	Ransomware affiliate since 2021	Microsoft observed it targeting US hospitals	Microsoft, 2024-09-26	[35] [48]
Phobos	none in ATT&CK	RaaS since May 2019	Public healthcare among targets	Advisory 2024-02-29	[26]
Ghost (Cring)	none in ATT&CK	Ransomware exploiting outdated software	Healthcare named	Advisory 2025-02-19	[29]

Actor	ATT&CK objects	Model or sponsor	Healthcare evidence	Latest dated record opened	Sources
Scattered Spider	G1015	Social-engineering crew that deploys ransomware, including DragonForce	None in the advisory; on the list for help-desk tradecraft	Advisory update 2025-07-29	[22]
CL0P	G0092 TA505, S0611	Data-theft extortion; exploited the MOVEit Transfer flaw CVE-2023-34362 (other campaigns in the home study)	Home study covers the victims	Advisory, June 2023	[28]
Andariel	G0138 (Maui has no ATT&CK object)	North Korea, RGB 3rd Bureau	Ransomware against US hospitals funds espionage	Advisory 2024-07-25; warrant 2024-07-24	[23] [24] [31]
Moonstone Sleet	G1036	North Korea	Has deployed Qilin	ATT&CK S1242 record	[43]
Pioneer Kitten	G0117 Fox Kitten	Iran-associated; ransomware side likely not sanctioned	Healthcare facilities among victims	Advisory 2024-08-28	[25]
Orangeworm (baseline)	G0071, S0236 Kwampirs	Likely corporate espionage since 2015	Healthcare in the US, Europe and Asia	ATT&CK group record	[49]

2.2 The ransomware operations

ALPHV Blackcat. ALPHV, also tracked as Noberus, is ransomware-as-a-service written in Rust and first seen in November 2021; Scattered Spider has deployed it [40] (**Confirmed**). In February 2023 it announced a "Sphynx" update that encrypts Windows, Linux and VMware instances [13]. Its affiliates pose as IT or help-desk staff by phone or SMS, capture MFA through adversary-in-the-middle pages, then install legitimate remote access software [13] (**Confirmed**). The advisory's February 2024 update records an administrator urging affiliates to target hospitals [13]; this study reads it as deliberate selection (**Inferred**).

LockBit. LockBit-named ransomware appeared on Russian-language forums in January 2020, after a predecessor called ABCD in September 2019 [19]. The FBI counted about 1,700 US attacks and about $91M in US ransoms by June 2023, with 1,653 leak-site victims through the first quarter of 2023 [19]. On 7 May 2024 the UK National Crime Agency named Russian national Dmitry Khoroshev as LockBitSupp, the administrator and developer; the UK, US and Australia sanctioned him and the US unsealed an indictment and offered up to $10m [33] (**Confirmed**). The Russia-based criminal side of the record, including this designation, also appears in Russia-Attributed Threat Actors: The Public Record. The NCA counted more than 7,000 attacks built with LockBit between June 2022 and February 2024, and says LockBit attacks targeted over 100 hospitals and healthcare companies, and an affiliate who attacked a children's hospital in December 2022 and stayed active until the February 2024 disruption [33] (**Confirmed**).

Black Basta. First identified in April 2022, Black Basta's affiliates hit over 500 organizations and 12 of 16 critical infrastructure sectors by May 2024 [14] (**Confirmed**). ATT&CK describes C++ ransomware with Windows and ESXi variants and operators who may include current or former Conti members [42]. Spearphishing is the main route; the others are phone and Teams calls posing as tech support after email bombing, exploitation of ScreenConnect CVE-2024-1709 from February 2024, valid accounts and user execution of remote tools [14] (**Confirmed**). Its notes carry no ransom figure, only a victim code and a Tor address, and it posts to its leak site within 10 to 12 days [14] [15].

RansomHub. RansomHub, formerly Cyclops and Knight, drew affiliates from LockBit and ALPHV and had at least 210 victims across 11 sectors between February and August 2024 [15] (**Confirmed**). ATT&CK records Windows, ESXi, Linux and FreeBSD versions and says the operators may have bought and rebranded Knight's resources [41]. Its routes are phishing, password spraying and exploits of Citrix, FortiOS, ActiveMQ, Confluence, BIG-IP and FortiClient EMS [15].

Medusa. Medusa began as a closed operation in June 2021 and moved to an affiliate model by early 2023; it had over 500 victims by April 2026, with medical named and HPH a frequent victim [16] (**Confirmed**). It pays initial access brokers $100 to $1M, often exploits new vulnerabilities within 24 hours of disclosure, and its advisory, as updated in 2026, lists GoAnywhere CVE-2025-10035 and BeyondTrust CVE-2026-1731 among the flaws it exploits [16] [82]. ATT&CK tracks the group as G1051 and the ransomware as S1244, which is a different object from S1220 MEDUSA [16] [46]. Victims can pay $10,000 to add a day to the leak countdown [16].

Akira. Akira has hit organizations since March 2023, added an ESXi Linux variant in April 2023, encrypts Nutanix AHV from June 2025, and had claimed about $244.17M by late September 2025 [20] (**Confirmed**). It gets in through VPNs without MFA, Cisco CVE-2020-3259 and CVE-2023-20269, SonicWall CVE-2024-40766 and stolen VPN credentials [20]. The FBI's 2024 complaint data puts Akira first among ransomware variants reported by critical infrastructure, ahead of LockBit, RansomHub, FOG and Play [37] (**Confirmed**).

Qilin. ATT&CK describes Qilin (also Agenda) as RaaS active since at least 2022 with victims mainly in manufacturing, technology, financial services and healthcare, and cites an HHS HC3 threat profile [43] (**Confirmed**). Water Galura (G1050) operates it, handling payloads, negotiation and leak publication for affiliates recruited on Russian forums [44]. Moonstone Sleet, a North Korean group, has deployed it [43]. The ATT&CK page does not mention the NHS or Synnovis [43]. Synnovis itself names no group [4]; the Qilin attribution for Synnovis appears in sources that could not be opened (an NHS England statement and the HC3 profile), so it is not checked here.

Interlock. First seen in late September 2024, Interlock is financially motivated and opportunistic and uses double extortion against organizations in North America and Europe [17] (**Confirmed**). Its initial access is distinctive: drive-by downloads from compromised legitimate sites, fake CAPTCHA pages that get users to paste and run commands (ClickFix, T1204.004), and fake browser or security updates [17]. The advisory does not name healthcare as a target sector, but HHS co-authored it and appended HPH guidance [17], and Kettering Health attributes its 2025 outage to Interlock [6] [7].

Rhysida. Rhysida has been deployed mainly since May 2023 against "targets of opportunity" in education, healthcare, manufacturing, IT and government; open-source reporting notes similarities to Vice Society (DEV-0832) [18] (**Confirmed**). It authenticates to internal VPNs with compromised credentials, often where MFA is off, and operates in a RaaS capacity [18]. The advisory names no victims [18].

Royal and BlackSuit. Royal ransomware ran from about September 2022 to June 2023 and was rebranded as BlackSuit; demands were typically $1M to $10M, over $500M in total and $60M at the largest [21] (**Confirmed**). Phishing is the most common route and RDP accounts for about 13.3% [21]. HPH is in the sector tags with no healthcare-specific statement [21].

Play, INC Ransom, Phobos and Ghost. Play had about 900 affected entities by May 2025 and is presumed to be a closed group; its advisory does not name healthcare, but ATT&CK's G1040 description does [27] [83]. INC Ransom (GOLD IONIC) has been active since July 2023 against industrial, healthcare and education

targets in the US and Europe, and its ATT&CK record cites reporting on a threat to leak NHS Scotland data [47]. Phobos, likely linked to the Elking, Eight, Devos, Backmydata and Faust variants, has public healthcare among its targets [26]. Ghost (Cring) exploits outdated FortiOS, ColdFusion, SharePoint and Exchange servers and usually takes little data [29] (all **Confirmed**).

Storm-0501. Microsoft reported in September 2024 that Storm-0501 had recently targeted US hospitals and had used Hive, BlackCat, Hunters International, LockBit and most recently Embargo payloads [35] (**Confirmed**). ATT&CK lists it as financially motivated since 2021 [48].

Scattered Spider. The advisory's sector focus is commercial facilities, not healthcare [22]. It is on this list because its methods (help-desk impersonation, MFA fatigue, SIM swaps, remote access tools, exfiltration to cloud storage) are the identity attacks the healthcare advisories warn about, and because it has deployed ALPHV and, from the July 2025 update, DragonForce [22] [40] (**Confirmed**).

CL0P. CL0P began exploiting the MOVEit Transfer SQL injection CVE-2023-34362 on 27 May 2023 [28] (**Confirmed**). Its data-theft model and victims are covered in The Cl0p MOVEit Breach.

2.3 The state-linked actors

Russia-linked and China-linked activity against healthcare (vaccine-research espionage, NotPetya collateral damage, espionage against research institutions) is collected in the healthcare sections of Russia-Attributed Threat Actors and China-Attributed Threat Actors; this watchlist keeps to 2023 to 2026 ransomware and the North Korea and Iran threads.

North Korea: Andariel and Maui. Since at least May 2021, North Korean state-sponsored actors have used Maui ransomware against HPH organizations, encrypting servers for electronic health records, diagnostics, imaging and intranet services [23] (**Confirmed**). The July 2024 advisory, led by the FBI with the Cyber National Mission Force (CNMF), CISA, DC3, NSA, South Korea's NIS and National Police Agency and the UK NCSC, with contributions from Mandiant and Microsoft, attributes the activity to Andariel of the RGB 3rd Bureau [24] (**Confirmed**). Its key sentence: the actors "fund their espionage activity through ransomware operations against U.S. healthcare entities", sometimes on the same day or against the same victim [24]. A federal warrant for Rim Jong Hyok was issued in the District of Kansas on 24 July 2024 for conspiring to hack and to launder money through Maui intrusions against US hospitals and healthcare companies [31], and Rewards for Justice offers up to $10 million, saying the ransoms paid for operations against US government and defense targets [32] (**Confirmed**). ATT&CK tracks Andariel as G0138, active since at least 2009, with Silent Chollima, PLUTONIUM and Onyx Sleet as associated names [45]. Maui has no ATT&CK object [83]. Andariel's wider record, with a healthcare view of Maui, sits in Other State-Linked Threat Actors: The Public Record, and the full North Korea record, including the dispute over who built Maui, is in North Korea-Attributed Threat Actors: The Public Record.

North Korea: Moonstone Sleet. ATT&CK records that Moonstone Sleet (G1036) has deployed Qilin [43] (**Confirmed**). No advisory on its healthcare activity was opened here.

Iran: Pioneer Kitten. Pioneer Kitten, also Fox Kitten, Lemon Sandstorm and the moniker Br0k3r, is associated with the Iranian government, but the FBI judges its ransomware activity likely not government-sanctioned [25] (**Confirmed**). It partnered with ALPHV, NoEscape and RansomHouse affiliates, counted US healthcare facilities among its victims, and got in through CVE-2024-3400 (PAN-OS), CVE-2022-1388 (BIG-IP), CVE-2019-19781 and CVE-2023-3519 (NetScaler), CVE-2024-21887 (Ivanti) and CVE-2024-24919 (Check Point) [25]. ATT&CK's G0117 lists healthcare among its targeted verticals [83]. The

actor's full record, including its access brokering for ransomware affiliates, is the subject of Iran-Attributed Threat Actors: The Public Record; this study keeps only the healthcare thread.

The espionage baseline: Orangeworm. The pre-2023 baseline for espionage against the sector in ATT&CK is Orangeworm (G0071), which has targeted healthcare in the US, Europe and Asia since at least 2015, likely for corporate espionage, using Kwampirs [49] (**Confirmed**).

2.4 What is not in ATT&CK

Rhysida, Interlock, BlackSuit, Maui, Hive, Phobos, 8Base, Karakurt, Daixin, Ghost (Cring) and DragonForce have no ATT&CK group or software object in the library's ATT&CK v20.0 data [83] (**Confirmed**). Defenders mapping coverage by ATT&CK object will miss them and should use the advisories' own technique tables, which Part 6 does.

Part 3: how they get in and how they extort

3.1 Initial access, actor by actor

Actor	Initial access in the advisory	ATT&CK ids the advisory gives	Sources
Black Basta	Spearphishing; phone and Teams calls posing as tech support after email bombing; ScreenConnect CVE-2024-1709; valid accounts; user execution of remote tools	T1566, T1566.004, T1190, T1078, T1204	[14]
ALPHV affiliates	Calls or SMS posing as IT or help desk; adversary-in-the-middle MFA capture; legitimate remote access software	T1598, T1557	[13]
Scattered Spider	Help-desk resets and MFA moves, SIM swaps, MFA fatigue, voice phishing, impersonation, trusted relationships	T1621, T1566.004, T1199; impersonation cited as T1656, now T1684.001	[22]
Rhysida	Compromised credentials on internal VPNs, often without MFA	T1078	[18]
RansomHub	Phishing, public-facing exploits (Citrix, FortiOS, ActiveMQ, Confluence, BIG-IP, FortiClient EMS), password spraying	T1566, T1190, T1110.003	[15]
Medusa	Initial access brokers, phishing, unpatched software (ScreenConnect, FortiClient EMS, GoAnywhere, BeyondTrust)	T1566, T1190	[16]
Akira	VPNs without MFA, Cisco and SonicWall flaws, stolen VPN credentials	T1078, T1133, T1190, T1566.001, T1566.002	[20]
Interlock	Drive-by downloads from compromised sites, fake CAPTCHA pages, fake updates	T1189, T1204.004	[17]
Royal / BlackSuit	Phishing (most common), RDP (about 13.3%), public-facing apps	(sector-level text)	[21]
LockBit	RDP and external remote services, public-facing exploits, phishing, valid accounts	(see Part 6)	[19]
Ghost	Outdated public-facing software (FortiOS, ColdFusion, SharePoint, Exchange)	T1190	[29]
Pioneer Kitten	Edge-device CVEs at PAN-OS, BIG-IP, NetScaler, Ivanti, Check Point	T1190	[25]
Daixin Team (2022)	Unpatched VPN server; phished credentials on a legacy VPN without MFA	(pre-window baseline)	[30]

3.2 Identity: the help desk and the VPN

The single most repeated weakness is a remote path that trusts a password. VPNs or gateways without MFA are among the stated ways in for Rhysida, Akira, Daixin Team and the hospital incidents Microsoft reviewed [18] [20] [30] [36] (**Confirmed**). The other half of the identity problem is people: ALPHV affiliates and Scattered Spider call the help desk or the user, posing as IT, to reset passwords or move MFA to a device they control [13] [22], and the Black Basta advisory's November 2024 update added Teams calls after email bombing [14] (**Confirmed**). Microsoft found phishing behind 93% of malicious activity in its review of 13 hospital systems [36] (**Confirmed** as Microsoft's own figure). The conclusion this study draws, that healthcare's initial access converges on identity and on edge and remote-tool exploitation rather than novel malware, is **Inferred** from these advisories.

3.3 Edge devices, remote tools and exploit tempo

The CVEs in the advisories are mostly the devices that face the internet (Part 5.4). Medusa often exploits new vulnerabilities within 24 hours of disclosure [16], and Black Basta exploited ScreenConnect CVE-2024-1709 in February 2024, the month it was disclosed [14] (**Confirmed**). Remote management tools are abused as well as exploited: Black Basta and ALPHV affiliates use ScreenConnect, AnyDesk, Quick Assist and Splashtop to hold access [13] [14] (**Confirmed**). Legacy systems appear in the Daixin case (a legacy VPN) and in Ghost's choice of outdated software and firmware [29] [30].

3.4 The virtualization layer

Encrypting the hypervisor takes down every clinical system on it at once (**Inferred**). ALPHV's Sphynx variant encrypts Windows, Linux and VMware [13]; Akira encrypts ESXi and, from June 2025, Nutanix AHV, and its advisory lists ESXi CVE-2024-37085 [20]; DragonForce, used by Scattered Spider, encrypts ESXi [22] (**Confirmed**). Black Basta and RansomHub have ESXi variants in their ATT&CK records [41] [42].

3.5 Extortion models

- **Double extortion is the norm.** Black Basta, RansomHub, Rhysida, Medusa, Akira, Interlock, Royal/BlackSuit and LockBit all steal before they encrypt [14] [15] [16] [17] [18] [19] [20] [21] (**Confirmed**). Black Basta posts to its leak site within 10 to 12 days, RansomHub within 3 to 90 days [14] [15].
- **Extortion without encryption.** Some ALPHV affiliates extort with stolen data and never deploy ransomware [13], and Scattered Spider sometimes does the same [22] (**Confirmed**).
- **No price in the note.** Black Basta and RansomHub notes carry only a victim code and a Tor address [14] [15].
- **A second extortion.** One Medusa victim was contacted by a separate actor who claimed the negotiator had stolen the payment and demanded more for the "true decryptor"; the advisory says this may be triple extortion or operational dysfunction [16] (**Confirmed**).
- **Publication.** Synnovis's attackers published stolen data from working drives on 20 June 2024, and Synnovis obtained an injunction against further publication [4]; DentaQuest's data was posted on the internet [11]; Change Healthcare screenshots were posted for about a week [34] (**Confirmed**).

3.6 Medical devices

CISA found an embedded backdoor with a hard-coded IP address in all three Contec CMS8000 patient-monitor firmware versions it examined, recorded as CVE-2025-0626 (CWE-912, hidden functionality) and CVE-2025-0683 (CWE-359, privacy exposure) [38] (**Confirmed**). The FDA says that once connected to the internet, the CMS8000 and the relabeled Epsimed MN-120 send patient data outside the care environment; it advises local monitoring only, with the network unplugged, and notes a July 2025 patch that removes networking [39] (**Confirmed**). HICP 2023 already lists attacks on connected medical devices among its five top threats [57].

3.7 What the sector figures say

The FBI's Internet Crime Complaint Center received 238 ransomware complaints and 206 data breach complaints from the Healthcare and Public Health sector in 2024: the most data breach complaints of any critical infrastructure sector, and second only to Critical Manufacturing (258) for ransomware [37] (**Confirmed**). Ransomware complaints from critical infrastructure rose 9% from 2023 [37]. Microsoft ranks healthcare among the ten most affected industries in the second quarter of 2024 and names Vanilla Tempest (INC ransomware), Lace Tempest, Sangria Tempest, Cadenza Tempest and Lemon Sandstorm as relevant to US healthcare [36] (**Confirmed**). The same Microsoft page relays survey figures from others: downtime costs of up to $900,000 a day, 67% of 402 surveyed healthcare organizations hit in the past year, 53% paying in 2024 against 42% in 2023, a median disclosed payment of $1.5M, and hospital mergers up 23% over 2022 [36] (**Reported**; the original surveys were not opened).

Part 4: the government and regulatory record

4.1 Voluntary goals and practices

- **HPH Cybersecurity Performance Goals.** HHS publishes ten Essential goals (mitigate known vulnerabilities, email security, MFA, basic training, strong encryption, revoke departing credentials, basic incident planning, unique credentials, separate user and privileged accounts, vendor requirements) and ten Enhanced goals (asset inventory, third-party vulnerability disclosure, third-party incident reporting, testing, mitigation, detecting and responding to relevant TTPs, segmentation, centralized logs, centralized incident planning, configuration management) [50] (**Confirmed**). CISA's toolkit says they were published "On January 25" without a year; January 2024 is inferred from the December 2023 concept paper that announced them [51] (**Inferred** year). They draw on the 2023 Hospital Cyber Resiliency Initiative Landscape Analysis, a 55-page HHS report [52].
- **HICP 2023.** The Health Industry Cybersecurity Practices answer Section 405(d) of the Cybersecurity Act of 2015; HHS convened the 405(d) Task Group in May 2017 and began the update in 2019 [57]. HICP names five top threats (social engineering, ransomware, attacks on connected medical devices, loss or theft of equipment or data, insider data loss) and ten practices with 88 sub-practices [57] (**Confirmed**). The old 405d.hhs.gov address now redirects to the HHS Cyber Gateway, whose newest dated items were from 2024 [58].
- **Recognized security practices.** Public Law 116-321 (5 January 2021) requires HHS to consider 12 months of recognized security practices, including those developed under section 405(d), when setting HIPAA fines, audits and remedies [59] (**Confirmed**).

- **CISA's sector work.** CISA, HHS and the HSCC Cybersecurity Working Group run an HPH toolkit [51]; CISA published the HPH Sector Mitigation Guide on 17 November 2023 as a companion to the July 2023 HPH Cyber Risk Summary [60]; and CISA names HHS as the sector's Sector Risk Management Agency, while still linking the 2015 Sector-Specific Plan [62] (**Confirmed**).
- **What the advisories tell the sector.** HHS co-authored advisories point HPH organizations to the CPGs and to HHS incident support "focused on mitigating adverse patient impacts" [17] (**Confirmed**); the Black Basta advisory also points to the CISA mitigation guide [14], and the Interlock advisory cites an HHS HC3 ClickFix sector alert [17].

4.2 The HIPAA Security Rule update

Date	Step	Sources
December 2023	HHS concept paper promises voluntary practices plus greater enforcement and accountability, including a Security Rule update (as HHS states it; the paper itself could not be opened)	[54]
2024-12-27	OCR issues the notice of proposed rulemaking	[53]
2025-01-06	Published at 90 FR 898 (FR doc 2024-30983, RIN 0945-AA22, docket HHS-OCR-2024-0020)	[53]
2025-03-07	Comments close; 4,747 counted	[53]
Spring 2025	Unified Agenda lists final action for May 2026, as an economically significant rule in the Regulatory Plan	[55]
Agenda 202510	Moved to Long-Term Actions, final action dated July 2027	[56]

The proposal would end the required and addressable distinction and require an asset inventory and network map at least every 12 months, a more specific risk analysis, written 72-hour restoration procedures, an annual compliance audit, annual verification of business associates' safeguards, encryption at rest and in transit, MFA, vulnerability scans every six months, annual penetration tests, network segmentation, separate backup controls, and 24-hour notice from business associates when they activate a contingency plan [54] (**Confirmed**). The current rule stays in effect meanwhile [54]. That no final rule had been issued by 3 November 2026 is **Inferred** from the agenda stage; no Federal Register search for a final rule was run.

4.3 OCR enforcement

OCR's resolution-agreement list shows a run of ransomware, phishing and risk-analysis cases from 2024 to 2026 [63] (**Confirmed**):

Date	Entity	What happened	Outcome	Sources
2025-01-07	OCR's eighth and ninth ransomware settlements	Listed on the resolution-agreement page; entities not checked	Listed	[63]
2025-01-14	Solara	Listed on the resolution-agreement page; details not checked	$3,000,000	[63]
2025-02-20	Warby Parker	Credential stuffing affecting 197,986 people; no accurate risk analysis	$1,500,000 civil money penalty	[68]

Date	Entity	What happened	Outcome	Sources
2025-05-30	Comstar (ambulance billing business associate)	Ransomware on 2022-03-19, detected 2022-03-26, 585,621 people; risk analysis failure	$75,000	[67]
2025-07-23	Syracuse ASC	Listed on the resolution-agreement page; details not checked	Listed	[63]
2025-08-18	BST & Co.	Ransomware case; details not checked	Listed	[63]
2026-07-29	OSF HealthCare	2021 Nephilim ransomware, 53,907 patients; no accurate risk analysis, impermissible disclosure, late notice	$552,250	[65]
2026-09-17	Ambry Genetics	Targeted phishing found 2020-01-22, 225,370 people; no risk analysis, termination procedures or unique user IDs	$700,000	[66]
2026-10-09	Lehigh Valley Health Network	Ransomware found in February 2023 in acquired Delta Medix's systems; PHI posted on the dark web	$800,000	[64]

The common finding is the missing or inaccurate risk analysis (**Inferred** from the cases opened). HHS moved its HIPAA news from 2015 to 19 January 2025 into an archive that requires a login, so older OCR releases cannot be opened directly [70] (**Confirmed**).

4.4 Other federal and state actions

- **FTC.** The amended Health Breach Notification Rule (89 FR 47028, published 30 May 2024, effective 29 July 2024) covers personal health record vendors outside HIPAA [71] (**Confirmed**).
- **New York.** The Department of Health published hospital cybersecurity requirements at 10 NYCRR 405.46 on 2 October 2024: 72-hour incident reporting at once, the rest after a year, a designated CISO, and a mapping to NIST CSF 2.0, NIST 800-53 r5 and HICP Volume 2 [72] (**Confirmed**).
- **State attorneys general.** Nebraska's case against Change Healthcare is in Part 1.3 [73] [74]. Thirty-three attorneys general settled with the clearinghouse Inmediata for $1.4M plus security reforms after PHI of about 1.5 million people sat indexed online for nearly three years (October 2023) [75]. A 44-attorney-general coalition settled with Labcorp in September 2026 over the 2019 AMCA debt-collector breach (over 27.5 million people, 10.2 million of them Labcorp patients), with vendor risk management terms [76] (**Confirmed**).

4.5 Congress

Bill	Sponsors	Introduced	What it would do	Latest action opened	Sources
S.5218, Health Infrastructure Security and Accountability Act of 2024	Wyden, Warner	2024-09-25 (Finance)	Minimum and enhanced security requirements, annual independent audits, higher penalties, an oversight user fee, Medicare cyber support and accelerated payments	Referred to committee	[77] [81]
S.5390, Health Care Cybersecurity and Resiliency Act of 2024	Cassidy, Hassan, Cornyn, Warner	2024-11-21 (HELP)	HHS and CISA coordination	Referred to committee	[78]
S.3315, Health Care Cybersecurity and Resiliency Act of 2025	Same four	2025-12-02 (HELP)	Coordination, best-practice grants, training through CISA State Coordinators, corrective actions shown on the breach portal	Later actions not checked	[79]
S.1851, Healthcare Cybersecurity Act of 2025	Rosen, Young	2025-05-21 (HSGAC)	A CISA and HHS liaison, coordination and sector training	Later actions not checked	[80]

None of these bills was found enacted; the record through 2026 is bills and hearings, not law (**Inferred** from introduced-only texts and referral-stage actions; status in the 119th Congress was not checked).

Part 5: the defender view

5.1 Where the sector is exposed

CISA's HPH Mitigation Guide draws on Cyber Hygiene scans of internet-facing HPH assets in 2022. The most common issues were web application vulnerabilities (89%), encryption weaknesses (89%), unsupported software (41%), unsupported Windows (36%), KEV entries (35%) and vulnerable services (34%) [61] (**Confirmed**). Its prioritized CVEs are CVE-2021-44228 (Log4j2, see Log4Shell), CVE-2019-11043, CVE-2012-1823, CVE-2021-34473 (ProxyShell, see Operation Exchange Marauder) and CVE-2017-12617, and the exposed services it lists are RDP, Telnet, FTP, SMB, RPC, NetBIOS, SNMP, Kerberos, LDAP and SQL [61] (**Confirmed**). It sets out three strategies: asset management; identity and device security; and vulnerability, patch and configuration management, and it maps CISA's cross-sector goals to HICP [60] (**Confirmed**).

5.2 The controls the advisories repeat

The same controls come back advisory after advisory; the list below follows the Medusa advisory [16] (**Confirmed** for [16]; that they recur across advisories is **Inferred**):

- Patch KEV entries on internet-facing systems first.
- Phishing-resistant MFA for all services where possible, particularly webmail, VPNs and accounts that reach critical systems [16]. ALPHV's advisory names FIDO/WebAuthn or PKI-based MFA [13].
- Offline, encrypted, immutable and tested backups.
- Segmentation and filtering of untrusted traffic to internal remote services; EDR and network monitoring for lateral movement.

- Least privilege, admin audits and checks of domain controllers for accounts nobody recognizes.
- Allowlisting of remote access software [13].

Advisory-specific additions:

- **Logging (Rhysida).** Command-line auditing, process tracking, PowerShell script block, module and transcription logging kept at least 180 days, restricted RDP and Remote Credential Guard [18] (**Confirmed**).
- **Credentials (LockBit).** Credential Guard, LAPS, NTLM limits and patching within 24 to 48 hours [19] (**Confirmed**).
- **Healthcare-specific (Black Basta).** Manage assets and their interdependencies, protect ePHI as HIPAA requires, run modern anti-malware, and map vulnerabilities to business-critical functions [14] (**Confirmed**).
- **Medical and IoT (Maui).** PKI and certificates for network, IoT medical device and health record access; no Telnet or SSH management on the WAN; encrypted PHI; multi-layer segmentation; IoT device monitoring [23] (**Confirmed**).
- **After edge exploitation (Pioneer Kitten).** Hunt for stolen credentials and footholds after patching, and check egress to file-sharing and tunnelling services [25] (**Confirmed**).
- **Fake-fix lures (Interlock).** DNS filtering, web access firewalls, and training users against fake-fix social engineering [17] (**Confirmed**).

5.3 The controls mapped to the HPH goals

The pairing of each goal with advisory evidence is this study's own (**Inferred**); every cell it rests on is **Confirmed** above.

HPH goal [50]	Why it matters on this watchlist	Techniques it addresses (Part 6)
Mitigate known vulnerabilities (Essential)	61 of 76 advisory CVEs are in KEV; Medusa exploits within 24 hours [16] [82]	T1190, T1133, T1068
Multifactor authentication (Essential)	VPNs without MFA in Rhysida, Akira, Daixin [18] [20] [30]	T1078, T1110.003, T1133
Email security and basic training (Essential)	Phishing (T1566 or a sub-technique) in 5 of 11 advisories; voice phishing and fake-fix lures [14] [17]	T1566, T1566.004, T1204.004, T1189
Separate user and privileged accounts (Essential)	Valid accounts and domain discovery recur [18] [20]	T1078.002, T1482, T1087.002
Vendor and supplier requirements (Essential)	Business associates carry the largest 2025 entry and several of the largest 2023 and 2026 entries [1]	T1199 Trusted Relationship (named only in the Scattered Spider advisory [22], so not in the 130)
Revoke credentials of departing staff, unique credentials (Essential)	Ambry Genetics' covered conduct included no termination procedures and no unique user IDs [66]	T1078
Asset inventory (Enhanced)	First of the three HPH guide strategies [60]	T1046, T1018

HPH goal [50]	Why it matters on this watchlist	Techniques it addresses (Part 6)
Network segmentation (Enhanced)	Maui advisory's multi-layer segmentation for medical devices [23]	T1021.001, T1210, T1133
Centralized log collection; detect and respond to relevant TTPs (Enhanced)	Rhysida's 180-day PowerShell logging [18]	T1059.001, T1685, T1047
Configuration management (Enhanced)	Remote-tool allowlisting [13]	T1219

5.4 Vulnerability management: the CVE to KEV join

The eleven healthcare-relevant advisories and the Play advisory name 76 distinct CVEs; 61 are in KEV at catalog version 2026.11.03, and most of the 15 that are not come from the Andariel advisory's list [82] (**Confirmed**: this study's join of the opened advisories with the KEV feed). The most repeated:

CVE	Product	Named in	KEV added	KEV ransomware use	Sources
CVE-2020-1472	Microsoft Netlogon	Black Basta, RansomHub, LockBit	2021-11-03	Known	[14] [15] [19] [82]
CVE-2023-3519	Citrix NetScaler ADC and Gateway	RansomHub, Andariel, Pioneer Kitten	2023-07-19	Known	[15] [24] [25] [82]
CVE-2018-13379	Fortinet FortiOS	LockBit, Play	2021-11-03	Known	[19] [27] [82]
CVE-2019-0708	Microsoft Remote Desktop Services	Andariel, LockBit	2021-11-03	Known	[19] [24] [82]
CVE-2021-44228	Apache Log4j2	Andariel, LockBit	2021-12-10	Known	[19] [24] [82]
CVE-2023-0669	Fortra GoAnywhere MFT	Andariel, LockBit	2023-02-10	Known	[19] [24] [82]
CVE-2023-27997	Fortinet FortiOS and FortiProxy SSL-VPN	RansomHub, Andariel	2023-06-13	Known	[15] [24] [82]
CVE-2023-46604	Apache ActiveMQ	RansomHub, Andariel	2023-11-02	Known	[15] [24] [82]
CVE-2023-48788	Fortinet FortiClient EMS	RansomHub, Medusa	2024-03-25	Known	[15] [16] [82]
CVE-2024-1709	ConnectWise ScreenConnect	Black Basta, Medusa	2024-02-22	Known	[14] [16] [82]
CVE-2024-37085	VMware ESXi	Akira	2024-07-30	Known	[20] [82]
CVE-2025-10035	Fortra GoAnywhere MFT	Medusa	2025-09-29	Known	[16] [82]
CVE-2026-1731	BeyondTrust Remote Support and Privileged Remote Access	Medusa	2026-02-13	Known	[16] [82]

Edge and remote-access products dominate the joined list: NetScaler, Fortinet, Cisco ASA and FTD, SonicWall, Ivanti, PAN-OS, Check Point, F5, ScreenConnect, SimpleHelp and BeyondTrust, plus Veeam backup and ESXi (**Inferred** from the join). For a healthcare vulnerability program, that means the patch queue for remote access, backup and hypervisor products should run on a clock of days, not a monthly cycle (**Inferred**). See the CVE Reference for the library's per-CVE entries and the Intelligence Hub for the live KEV

ledger.

5.5 Third-party risk

Business associates carry the largest breach of 2025 and several of the largest of 2023 and 2026 [1] (**Inferred** from the entity types in the export), Lumexa's breach was in its vendor's system [12], the Labcorp settlement imposed vendor risk management terms [76], the proposed Security Rule would require annual verification of business associates' safeguards and 24-hour contingency notices [54], and the HPH goals include vendor requirements and third-party incident reporting [50] (**Confirmed** for each). Change Healthcare showed what one business associate's outage can do to a whole sector (Part 1.3).

5.6 Detection priorities from the technique frequency

The techniques that appear in the most healthcare-relevant advisories are a reasonable place to start detection engineering (**Inferred**; the counts are this study's, Part 6):

Technique	Advisories (of 11)	Detection and control focus (D3FEND page where the library maps one)
T1486 Data Encrypted for Impact	8	Restore File; offline backups
T1059.001 PowerShell	7	Process Spawn Analysis; script block logging [18]
T1190 Exploit Public-Facing Application	7	Software Update; Inbound Traffic Filtering
T1219 Remote Access Tools	7	Executable Allowlisting; Outbound Traffic Filtering
T1021.001 Remote Desktop Protocol	6	Remote Terminal Session Detection; Disable Remote Access
T1685 Disable or Modify Tools	6	Alert on security-tool tampering
T1078 Valid Accounts	5	User Account Permissions; Multi-factor Authentication
T1490 Inhibit System Recovery	5	Protect and monitor shadow copies and backup consoles
T1657 Financial Theft	5	Extortion response planning
T1572 Protocol Tunneling	4	Outbound Traffic Filtering
T1567.002 Exfiltration to Cloud Storage	4	Outbound Traffic Filtering
T1482 Domain Trust Discovery	4	Domain Account Monitoring

5.7 Medical device handling

Treat a monitor that can phone home as a network risk, not only a clinical device. For the Contec CMS8000 and Epsimed MN-120, the FDA's advice is local monitoring with the network unplugged and the July 2025 patch that removes networking [39]; the Maui advisory's controls (certificates for device access, segmentation, IoT monitoring) apply to the rest of the fleet [23] (**Confirmed**).

5.8 What is overstated and what is understated

Overstated.

- **The breach count as a measure of the threat.** The yearly totals of individuals turn on one or two entries: Change Healthcare is about 66% of 2024 and Conduent about 44% of 2025, and the same person can be counted in more than one report [1] (**Inferred** from **Confirmed** entries). A year with a smaller total is not a safer year for hospitals; it is a year without a giant vendor breach.
- **The group name as the explanation.** Most victim notices name no group [3] [4] [5] [8], and a widely repeated attribution such as Qilin for Synnovis rests on sources this study could not open (Part 2.2). Coverage planning keyed to one brand misses the affiliates who move between LockBit, ALPHV and RansomHub [15] (**Inferred**).
- **Medical devices as the main way in.** The device record opened here is a firmware backdoor that sends patient data out of the care environment and a handling advisory [38] [39]; none of the initial access routes the advisories give in Part 3.1 is a medical device (**Inferred** from that table). Devices matter for segmentation and data exposure, but the intrusions start elsewhere.
- **State actors as the main threat.** Three of the 21 actors on the list are state-linked, and the North Korean activity bound here is ransomware run for revenue [24] [43] (**Inferred**). The controls that stop a state-linked intrusion are the ones that stop a criminal one (Cross-cutting themes).
- **Survey figures on cost and payment rates.** The downtime and payment figures relayed on the Microsoft page come from surveys this study did not open [36] (**Reported**); treat them as indications, not measurements.

Understated.

- **Vendors and business associates.** They carry the largest counts in every year of the window [1] [9] [10] [12], and Change Healthcare showed what one business associate's outage does to a whole sector (Parts 1.3 and 5.5, **Inferred** from **Confirmed** entries).
- **The help desk and the remote path that trusts a password.** Phone and help-desk social engineering and VPN logins without MFA recur across the advisories [13] [14] [18] [20] [22] and in Microsoft's hospital review [36] (**Confirmed**). They are the first two of this study's top recommendations for that reason.
- **The hypervisor.** ALPHV, Akira and DragonForce encrypt the virtualization layer, which takes down every clinical system on a host at once [13] [20] [22] (**Confirmed** for the capability; the effect is **Inferred**).
- **What patching does not do.** The Pioneer Kitten advisory warns that patching an exploited edge device does not remove an intruder already inside [25] (**Confirmed**).
- **The gaps in ATT&CK.** Eleven operations on or near this list, Rhysida and Interlock among them, have no ATT&CK object in the library's v20.0 data [83] (**Confirmed**), so a coverage map built from ATT&CK objects alone misses them (Part 2.4).
- **How long disclosure takes.** Change Healthcare's count took more than a year to settle [69] and Synnovis finished notifications in November 2025 [4] (**Confirmed**); sector statistics drawn from notices trail the attacks (**Inferred**).

Part 6: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 (Enterprise), CWE, CAPEC and D3FEND. Every technique id below is live in the library's `data/attack/technique_profiles.jsonl`, which supplies the names and tactics, and has a generated page under `mitre/techniques/` [83]. Every mapping comes from a cited joint advisory's own technique table; mappings no source states are left out. ATT&CK for ICS does not apply: no event in this study touched an industrial control system.

6.1 Objects

Object	ATT&CK id	Library page	Relationship to this study
Andariel	G0138	/mitre/groups/G0138.md	RGB 3rd Bureau; Maui operations against US healthcare [24] [45]
Moonstone Sleet	G1036	/mitre/groups/G1036.md	Has deployed Qilin [43]
Fox Kitten	G0117	/mitre/groups/G0117.md	Pioneer Kitten; access partner for ransomware affiliates [25] [83]
Akira	G1024	/mitre/groups/G1024.md	AA24-109A [20]
Play	G1040	/mitre/groups/G1040.md	Healthcare named in the ATT&CK description [83]
Medusa Group	G1051	/mitre/groups/G1051.md	Created 2025-10-15, modified 2026-07-31; the page does not mention healthcare [46]
Scattered Spider	G1015	/mitre/groups/G1015.md	Help-desk tradecraft; deployed BlackCat [22] [40]
INC Ransom	G1032	/mitre/groups/G1032.md	Industrial, healthcare and education targets [47]
Water Galura	G1050	/mitre/groups/G1050.md	Operates Qilin [44]
Storm-0501	G1053	/mitre/groups/G1053.md	Targeted US hospitals per Microsoft [35] [48]
TA505	G0092	/mitre/groups/G0092.md	CL0P; MOVEit [28]
Orangeworm	G0071	/mitre/groups/G0071.md	Healthcare espionage baseline since 2015 [49]
BlackCat	S1068	/mitre/software/S1068.md	ALPHV, Noberus [40]
Black Basta	S1070	/mitre/software/S1070.md	[42]
RansomHub	S1212	/mitre/software/S1212.md	[41]
LockBit 2.0	S1199	/mitre/software/S1199.md	[19]
LockBit 3.0	S1202	/mitre/software/S1202.md	[19]
Akira	S1129	/mitre/software/S1129.md	[20]
Akira _v2	S1194	/mitre/software/S1194.md	[20]
Medusa Ransomware	S1244	/mitre/software/S1244.md	Not S1220 MEDUSA, a different object [16]
Qilin	S1242	/mitre/software/S1242.md	Page created 2025-09-26, modified 2026-04-23 [43]
Playcrypt	S1162	/mitre/software/S1162.md	[27]
INC Ransomware	S1139	/mitre/software/S1139.md	[47]
Embargo	S1247	/mitre/software/S1247.md	Storm-0501's latest payload [35]
Royal	S1073	/mitre/software/S1073.md	BlackSuit has no ATT&CK object [21]
Clop	S0611	/mitre/software/S0611.md	[28]

Object	ATT&CK id	Library page	Relationship to this study
Kwampirs	S0236	/mitre/software/S0236.md	Orangeworm's tool [49]

No campaign (C####) object is bound: none of the sources opened ties one of these events to an ATT&CK campaign id. Rhysida, Interlock, BlackSuit, Maui, Phobos, Daixin Team and the other names in Part 2.4 have no object [83].

6.2 ATT&CK Enterprise techniques (130)

Each row lists the healthcare-relevant joint advisories that name the technique in their own mapping tables, with the advisory's publication and update dates. The count column is the number of the eleven advisories that name it. Ids link to the library's generated technique pages.

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1003	OS Credential Dumping	Credential Access	4	AA24-242A RansomHub (2024-08-29); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25)	[15] [19] [20] [24]
T1003.001	LSASS Memory	Credential Access	3	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [19] [20]
T1003.002	Security Account Manager	Credential Access	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1003.003	NTDS	Credential Access	2	AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[18] [20]
T1006	Direct Volume Access	Stealth	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1007	System Service Discovery	Discovery	1	AA25-203A Interlock (2025-07-22)	[17]
T1012	Query Registry	Discovery	1	AA24-241A Pioneer Kitten (2024-08-28)	[25]
T1016	System Network Configuration Discovery	Discovery	4	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [17] [18] [20]
T1018	Remote System Discovery	Discovery	3	AA24-242A RansomHub (2024-08-29); AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[15] [18] [20]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1021	Remote Services	Lateral Movement	2	AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25)	[20] [24]
T1021.001	Remote Desktop Protocol	Lateral Movement	6	AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[15] [16] [17] [18] [19] [20]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	2	AA23-165A LockBit (2023-06-14); AA24-207A Andariel (2024-07-25)	[19] [24]
T1021.004	SSH	Lateral Movement	2	AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[18] [20]
T1027	Obfuscated Files or Information	Stealth	4	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25)	[16] [19] [20] [24]
T1027.002	Software Packing	Stealth	1	AA23-165A LockBit (2023-06-14)	[19]
T1027.013	Encrypted/Encoded File	Stealth	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1027.015	Compression	Stealth	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1033	System Owner/User Discovery	Discovery	3	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15)	[16] [17] [18]
T1036	Masquerading	Stealth	3	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[14] [15] [20]
T1036.005	Match Legitimate Resource Name or Location	Stealth	1	AA25-203A Interlock (2025-07-22)	[17]
T1039	Data from Network Shared Drive	Collection	1	AA24-207A Andariel (2024-07-25)	[24]
T1040	Network Sniffing	Credential Access, Discovery	1	AA24-207A Andariel (2024-07-25)	[24]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1046	Network Service Discovery	Discovery	4	AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[15] [16] [19] [20]
T1047	Windows Management Instrumentation	Execution	2	AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[15] [16]
T1048	Exfiltration Over Alternative Protocol	Exfiltration	4	AA25-203A Interlock (2025-07-22); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25)	[17] [19] [20] [24]
T1048.002	Exfiltration Over Asymmetric Encrypted Non-C2 Protocol	Exfiltration	1	AA24-242A RansomHub (2024-08-29)	[15]
T1048.003	Exfiltration Over Unencrypted Non-C2 Protocol	Exfiltration	1	AA24-242A RansomHub (2024-08-29)	[15]
T1049	System Network Connections Discovery	Discovery	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1053	Scheduled Task/Job	Execution, Persistence, Privilege Escalation	1	AA24-241A Pioneer Kitten (2024-08-28)	[25]
T1055.002	Portable Executable Injection	Stealth, Privilege Escalation	1	AA23-319A Rhysida (2023-11-15)	[18]
T1056	Input Capture	Collection, Credential Access	2	AA25-203A Interlock (2025-07-22); AA24-241A Pioneer Kitten (2024-08-28)	[17] [25]
T1056.001	Keylogging	Collection, Credential Access	1	AA25-203A Interlock (2025-07-22)	[17]
T1057	Process Discovery	Discovery	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1059	Command and Scripting Interpreter	Execution	1	AA24-207A Andariel (2024-07-25)	[24]
T1059.001	PowerShell	Execution	7	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28)	[14] [15] [16] [17] [18] [20] [25]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1059.003	Windows Command Shell	Execution	4	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [18] [19] [20]
T1059.005	Visual Basic	Execution	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1059.009	Cloud API	Execution	1	AA23-319A Rhysida (2023-11-15)	[18]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	3	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[14] [15] [20]
T1069.001	Local Groups	Discovery	2	AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[18] [20]
T1069.002	Domain Groups	Discovery	3	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [18] [20]
T1070	Indicator Removal	Stealth	2	AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[15] [16]
T1070.003	Clear Command History	Stealth	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1070.004	File Deletion	Stealth	3	AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14)	[17] [18] [19]
T1071	Application Layer Protocol	Command and Control	1	AA24-207A Andariel (2024-07-25)	[24]
T1071.001	Web Protocols	Command and Control	2	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14)	[16] [19]
T1071.002	File Transfer Protocols	Command and Control	1	AA23-165A LockBit (2023-06-14)	[19]
T1072	Software Deployment Tools	Execution, Lateral Movement	2	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14)	[16] [19]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	5	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[14] [17] [18] [19] [20]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1078.002	Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	2	AA25-203A Interlock (2025-07-22); AA24-241A Pioneer Kitten (2024-08-28)	[17] [25]
T1078.003	Local Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	1	AA24-241A Pioneer Kitten (2024-08-28)	[25]
T1082	System Information Discovery	Discovery	4	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [17] [19] [20]
T1083	File and Directory Discovery	Discovery	2	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA24-207A Andariel (2024-07-25)	[16] [24]
T1087	Account Discovery	Discovery	1	AA24-207A Andariel (2024-07-25)	[24]
T1087.002	Domain Account	Discovery	2	AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[18] [20]
T1090	Proxy	Command and Control	2	AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25)	[20] [24]
T1090.003	Multi-hop Proxy	Command and Control	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1095	Non-Application Layer Protocol	Command and Control	1	AA23-165A LockBit (2023-06-14)	[19]
T1098	Account Manipulation	Persistence, Privilege Escalation	3	AA24-242A RansomHub (2024-08-29); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28)	[15] [20] [25]
T1105	Ingress Tool Transfer	Command and Control	3	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [17] [20]
T1110	Brute Force	Credential Access	2	AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[19] [20]
T1110.003	Password Spraying	Credential Access	2	AA24-242A RansomHub (2024-08-29); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[15] [20]
T1112	Modify Registry	Defense Impairment, Persistence	1	AA23-319A Rhysida (2023-11-15)	[18]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1133	External Remote Services	Persistence, Initial Access	3	AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28)	[19] [20] [25]
T1135	Network Share Discovery	Discovery	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1136	Create Account	Persistence	2	AA24-242A RansomHub (2024-08-29); AA24-241A Pioneer Kitten (2024-08-28)	[15] [25]
T1136.001	Local Account	Persistence	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1136.002	Domain Account	Persistence	2	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [20]
T1189	Drive-by Compromise	Initial Access	2	AA25-203A Interlock (2025-07-22); AA23-165A LockBit (2023-06-14)	[17] [19]
T1190	Exploit Public-Facing Application	Initial Access	7	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25); AA24-241A Pioneer Kitten (2024-08-28)	[14] [15] [16] [19] [20] [24] [25]
T1204	User Execution	Execution	1	AA24-131A Black Basta (2024-05-10, revised 2024-11-08)	[14]
T1204.004	Malicious Copy and Paste	Execution	1	AA25-203A Interlock (2025-07-22)	[17]
T1210	Exploitation of Remote Services	Lateral Movement	1	AA24-242A RansomHub (2024-08-29)	[15]
T1218.011	Rundll32	Stealth	1	AA25-203A Interlock (2025-07-22)	[17]
T1218.014	MMC	Stealth	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1219	Remote Access Tools	Command and Control	7	AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28)	[15] [16] [17] [18] [19] [20] [25]
T1222.001	Windows Permissions	Defense Impairment	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1480.001	Environmental Keying	Stealth	1	AA23-165A LockBit (2023-06-14)	[19]
T1482	Domain Trust Discovery	Discovery	4	AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28)	[18] [19] [20] [25]
T1484.001	Group Policy Modification	Defense Impairment, Privilege Escalation	2	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14)	[16] [19]
T1485	Data Destruction	Impact	1	AA23-165A LockBit (2023-06-14)	[19]
T1486	Data Encrypted for Impact	Impact	8	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA22-187A Maui (2022-07-06)	[14] [15] [16] [17] [18] [19] [20] [23]
T1489	Service Stop	Impact	2	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14)	[16] [19]
T1490	Inhibit System Recovery	Impact	5	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[14] [15] [16] [19] [20]
T1491.001	Internal Defacement	Impact	1	AA23-165A LockBit (2023-06-14)	[19]
T1505	Server Software Component	Persistence	1	AA24-241A Pioneer Kitten (2024-08-28)	[25]
T1505.003	Web Shell	Persistence	1	AA24-241A Pioneer Kitten (2024-08-28)	[25]
T1529	System Shutdown/Reboot	Impact	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1530	Data from Cloud Storage	Collection	2	AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15)	[17] [18]
T1537	Transfer Data to Cloud Account	Exfiltration	2	AA24-242A RansomHub (2024-08-29); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[15] [20]
T1547	Boot or Logon Autostart Execution	Persistence, Privilege Escalation	1	AA23-165A LockBit (2023-06-14)	[19]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1547.001	Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	1	AA25-203A Interlock (2025-07-22)	[17]
T1548	Abuse Elevation Control Mechanism	Privilege Escalation	1	AA23-165A LockBit (2023-06-14)	[19]
T1550.002	Pass the Hash	Lateral Movement	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1555	Credentials from Password Stores	Credential Access	2	AA23-353A ALPHV Blackcat (2023-12-19, updated 2024-02-27); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[13] [20]
T1555.003	Credentials from Web Browsers	Credential Access	3	AA25-203A Interlock (2025-07-22); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[17] [19] [20]
T1555.004	Windows Credential Manager	Credential Access	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1557	Adversary-in-the-Middle	Credential Access, Collection	1	AA23-353A ALPHV Blackcat (2023-12-19, updated 2024-02-27)	[13]
T1558	Steal or Forge Kerberos Tickets	Credential Access	2	AA23-353A ALPHV Blackcat (2023-12-19, updated 2024-02-27); AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[13] [16]
T1558.003	Kerberoasting	Credential Access	1	AA25-203A Interlock (2025-07-22)	[17]
T1560	Archive Collected Data	Collection	1	AA24-207A Andariel (2024-07-25)	[24]
T1560.001	Archive via Utility	Collection	2	AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[19] [20]
T1564.003	Hidden Window	Stealth	1	AA23-319A Rhysida (2023-11-15)	[18]
T1564.012	File/Path Exclusions	Stealth	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1566	Phishing	Initial Access	4	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14)	[14] [15] [16] [19]
T1566.001	Spearphishing Attachment	Initial Access	2	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[14] [20]
T1566.002	Spearphishing Link	Initial Access	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1566.004	Spearphishing Voice	Initial Access	1	AA24-131A Black Basta (2024-05-10, revised 2024-11-08)	[14]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1567	Exfiltration Over Web Service	Exfiltration	2	AA23-165A LockBit (2023-06-14); AA24-207A Andariel (2024-07-25)	[19] [24]
T1567.002	Exfiltration to Cloud Storage	Exfiltration	4	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [17] [19] [20]
T1569.002	Service Execution	Execution	3	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13)	[16] [19] [20]
T1572	Protocol Tunneling	Command and Control	4	AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-207A Andariel (2024-07-25); AA24-241A Pioneer Kitten (2024-08-28)	[19] [20] [24] [25]
T1573.002	Asymmetric Cryptography	Command and Control	1	AA24-109A Akira (2024-04-18, updated 2025-11-13)	[20]
T1586	Compromise Accounts	Resource Development	1	AA23-353A ALPHV Blackcat (2023-12-19, updated 2024-02-27)	[13]
T1587	Develop Capabilities	Resource Development	1	AA23-319A Rhysida (2023-11-15)	[18]
T1587.001	Malware	Resource Development	1	AA24-207A Andariel (2024-07-25)	[24]
T1587.004	Exploits	Resource Development	1	AA24-207A Andariel (2024-07-25)	[24]
T1588.005	Exploits	Resource Development	1	AA24-242A RansomHub (2024-08-29)	[15]
T1591	Gather Victim Org Information	Reconnaissance	1	AA24-207A Andariel (2024-07-25)	[24]
T1592	Gather Victim Host Information	Reconnaissance	1	AA24-207A Andariel (2024-07-25)	[24]
T1595	Active Scanning	Reconnaissance	1	AA24-207A Andariel (2024-07-25)	[24]
T1596	Search Open Technical Databases	Reconnaissance	2	AA24-207A Andariel (2024-07-25); AA24-241A Pioneer Kitten (2024-08-28)	[24] [25]
T1598	Phishing for Information	Reconnaissance	1	AA23-353A ALPHV Blackcat (2023-12-19, updated 2024-02-27)	[13]
T1614.001	System Language Discovery	Discovery	1	AA23-165A LockBit (2023-06-14)	[19]

ID	Name	Tactic(s)	Advisories	Dated report	Sources
T1657	Financial Theft	Impact	5	AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA25-203A Interlock (2025-07-22); AA23-319A Rhysida (2023-11-15); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28)	[16] [17] [18] [20] [25]
T1675	ESXi Administration Command	Execution	1	AA25-071A Medusa (2025-03-12, updated 2026-08-18)	[16]
T1685	Disable or Modify Tools	Defense Impairment	6	AA24-131A Black Basta (2024-05-10, revised 2024-11-08); AA24-242A RansomHub (2024-08-29); AA25-071A Medusa (2025-03-12, updated 2026-08-18); AA23-165A LockBit (2023-06-14); AA24-109A Akira (2024-04-18, updated 2025-11-13); AA24-241A Pioneer Kitten (2024-08-28) (some advisories cite the revoked id T1562.001)	[14] [15] [16] [19] [20] [25]
T1685.005	Clear Windows Event Logs	Defense Impairment	2	AA23-319A Rhysida (2023-11-15); AA23-165A LockBit (2023-06-14) (some advisories cite the revoked id T1070.001)	[18] [19]
T1686	Disable or Modify System Firewall	Defense Impairment	1	AA24-109A Akira (2024-04-18, updated 2025-11-13) (some advisories cite the revoked id T1562.004)	[20]
T1689	Downgrade Attack	Defense Impairment	1	AA24-241A Pioneer Kitten (2024-08-28) (some advisories cite the revoked id T1562.010)	[25]

6.3 Revoked and excluded ids

Id as cited	Where	Status in ATT&CK v20.0	Used instead	Sources
T1562.001 Disable or Modify Tools	Black Basta, RansomHub, Akira, LockBit, Pioneer Kitten advisories	Revoked	`T1685`	[83]
T1070.001 Clear Windows Event Logs	Rhysida, LockBit advisories	Revoked	`T1685.005`	[83]
T1562.004 Disable or Modify System Firewall	Akira advisory	Revoked	`T1686`	[83]
T1562.010 Downgrade Attack	Pioneer Kitten advisory	Revoked	`T1689`	[83]
T1656 Impersonation	Scattered Spider advisory (not counted)	Revoked	`T1684.001`	[83]
T1604 Proxy Through Victim	Akira advisory	Mobile domain	left out of the Enterprise layer	[20] [83]
T1451 SIM Card Swap, T1660 Phishing	Scattered Spider advisory	Mobile domain	left out	[22] [83]
T1059.008 Network Device CLI	Maui advisory, for generic command-line use	Treated as a mislabel (**Inferred**)	left out; only T1486 kept from [23]	[23]

The Medusa advisory's 2026 update already uses v20 ids such as T1685 and T1675 [16].

6.4 How the advisories compare with ATT&CK's own mappings

The union of the library's ATT&CK group and software mappings for the twelve groups (G0138, G1036, G0117, G1024, G1040, G1051, G1015, G1032, G1050, G1053, G0092, G0071) and fifteen software objects (S1068, S1070, S1212, S1199, S1202, S1129, S1194, S1244, S1242, S1162, S1139, S1247, S1073, S0611, S0236) bound in Part 6.1 holds 213 techniques, and 95 of the 130 advisory techniques fall inside it [83] (**Inferred**: this study's computation, rerun on 4 November 2026). The other 35 appear only in the advisories, which is one more reason to work from the advisories' tables rather than from ATT&CK object pages alone (**Inferred**).

6.5 CWE and CAPEC

Id	Name	Where it meets the record	Library relation	Sources
CWE-912	Hidden Functionality	Contec CMS8000 backdoor, CVE-2025-0626	The library relates it to CAPEC-133 Try All Common Switches and CAPEC-190 Reverse Engineer an Executable to Expose Assumed Hidden Functionality; neither describes a vendor-planted backdoor (**Inferred**)	[38] [83]
CWE-359	Exposure of Private Personal Information to an Unauthorized Actor	Contec CMS8000 patient-data exposure, CVE-2025-0683	The library relates it to CAPEC-464, CAPEC-467, CAPEC-498 and CAPEC-508, none of them device-specific (**Inferred**)	[38] [83]

CAPEC entries the library maps to techniques in Part 6.2 (from `data/weaknesses/capec.jsonl`, **Confirmed** for the library data):

CAPEC	Name	Technique it maps	Where it meets the record
CAPEC-98	Phishing	T1566, T1598	Black Basta, RansomHub, Medusa, LockBit; ALPHV information phishing
CAPEC-163	Spear Phishing	T1566.001, T1566.002	Black Basta, Akira
CAPEC-565	Password Spraying	T1110.003	RansomHub, Akira
CAPEC-560	Use of Known Domain Credentials	T1078	VPN logins without MFA
CAPEC-555	Remote Services with Stolen Credentials	T1133, T1021	Akira; Andariel
CAPEC-94	Adversary in the Middle (AiTM)	T1557	ALPHV MFA capture
CAPEC-509	Kerberoasting	T1558.003	Interlock
CAPEC-644	Use of Captured Hashes (Pass The Hash)	T1550.002	See Part 6.2
CAPEC-650	Upload a Web Shell to a Web Server	T1505.003	See Part 6.2
CAPEC-300	Port Scanning	T1046	RansomHub, Medusa, Akira, LockBit

See the CWE Reference and the CAPEC Reference.

6.6 D3FEND countermeasures

The library's D3FEND pages cover the countermeasures the advisories recommend. The library's own technique-to-D3FEND data maps T1486 to Restore File, T1219, T1572 and T1567.002 to Outbound Traffic Filtering and Remote Terminal Session Detection, T1021.001 to Remote Terminal Session Detection, T1078 to User Account Permissions, T1490 to Software Update, and T1110.003 to Multi-factor Authentication [83] (**Confirmed** for the data and the pages). The pairing of each advisory recommendation with a countermeasure below is **Inferred**.

Advisory recommendation	D3FEND countermeasure	Sources
Phishing-resistant MFA	Multi-factor Authentication	[13] [16]
Allowlist remote access tools	Executable Allowlisting	[13]
Patch KEV entries first	Software Update, System Vulnerability Assessment, Asset Vulnerability Enumeration	[16]
Asset inventory	Software Inventory, Network Node Inventory	[14] [60]
Segment and filter untrusted traffic	Network Traffic Filtering, Inbound Traffic Filtering	[16] [23]
Restrict RDP	Disable Remote Access, Remote Terminal Session Detection	[18]
Offline, tested backups	Restore File, Restore Database	[16]

Advisory recommendation	D3FEND countermeasure	Sources
Check for unrecognized AD accounts	Domain Account Monitoring	[16]
Least privilege	User Account Permissions	[16]
Credential Guard, LAPS	Credential Hardening	[19]
Command-line and process auditing	Process Spawn Analysis	[18]
Watch egress to file-sharing and tunnels	Outbound Traffic Filtering	[25]
DNS filtering (Interlock)	DNS Denylisting	[17]

See the D3FEND Reference.

6.7 Navigator layer

- Enterprise: `navigator/library-layers/healthcare-threat-watchlist-2023-2026.json` (open in Navigator), domain `enterprise-attack`, ATT&CK version 20, the 130 techniques of Part 6.2 in 153 technique and tactic entries.

Each technique is shown under all its tactics. The score is the number of the eleven advisories that name the technique (1 to 8), and each comment names the advisories and their source numbers in this study. A score measures how often the advisories name a technique, not severity. The layer lives in `navigator/library-layers/`, is listed in its `index.json` and in the Navigator layers index, and passes the library's `validate_navigator` check. The library's ransomware TTPs layer is the cross-sector companion.

Cross-cutting themes

- **Healthcare is chosen, not just hit.** The ALPHV administrator's call to target hospitals [13] and Andariel's use of healthcare ransom to fund espionage [24] show deliberate selection; LockBit's 100-plus hospital and healthcare targets [33] show the scale (**Inferred**). Care pressure makes payment more likely; that reading is **Inferred**.
- **The record runs through intermediaries.** Medusa pays initial access brokers [16], Pioneer Kitten works with ransomware affiliates [25], RaaS operators rent tools to affiliates, and business associates hold the largest data sets [1]. The defender's perimeter includes all of them (**Inferred**).
- **Names change faster than methods.** Royal became BlackSuit [21], Knight became RansomHub [15], affiliates move between LockBit, ALPHV and RansomHub [15], and Storm-0501 used six payloads in turn [35] [48]. Most initial access methods in Part 3.1 (phishing, VPN credentials, edge exploits) recur across four years, with fake-fix lures the notable newcomer (**Inferred**).
- **State and crime overlap.** North Korean units run ransomware for revenue [24] and deploy criminal RaaS [43]; an Iran-associated group works with criminal affiliates on its own account [25]. Attribution to a state does not change the controls that stop the intrusion (**Inferred**).
- **Disclosure lags and stays partial.** Change's count rose from a 500-person placeholder to 192.7 million over a year [69], Synnovis needed until November 2025 to finish notifications [4], and most victims never name the group (Part 1.5). Sector statistics drawn from notices will always trail the attacks (**Inferred**).

- **The baseline is voluntary.** The goals and practices are clear [50] [57], the proposed rule would make many of them mandatory [54], but the rule has slipped to 2027 [56] and the two 2024 bills were referred to committee and the 2025 bills' later actions were not checked [77] to [81].

Sources

Addresses shown as code rather than as links refuse automated link checkers: the hhs.gov pages, the sec.gov filing, the FBI wanted page and the New York regulation return 403 to scripted clients, and the api.congress.gov record needs a free api.data.gov key (the bill texts are on govinfo.gov). Each was opened for this study on the date given.

#	Source	URL	Opened	Grade
1	HHS Office for Civil Rights, Breach Portal: Under Investigation and Archive lists, CSV exports (500+ individuals)	https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf	3 Nov 2026	Confirmed
2	California Attorney General, data breach list (export with breach and reported dates)	https://oag.ca.gov/privacy/databreach/list-export	3 Nov 2026	Confirmed
3	Ascension, notice letter dated 2024-12-19 (California AG filing sb24-596447)	https://oag.ca.gov/ecrime/databreach/reports/sb24-596447	3 Nov 2026	Confirmed
4	Synnovis, June 2024 cyber incident updates	https://synnoviscyberupdate.co.uk/	3 Nov 2026	Confirmed
5	Prospect Medical Holdings, notice letter (California AG filing sb24-574490)	https://oag.ca.gov/ecrime/databreach/reports/sb24-574490	3 Nov 2026	Confirmed
6	Kettering Health, system-wide technology outage updates	https://ketteringhealth.org/system-wide-technology-outage/	3 Nov 2026	Confirmed
7	Kettering Health, cybersecurity incident FAQ	https://ketteringhealth.org/cybersecurity-incident-faq/	3 Nov 2026	Confirmed
8	DaVita Inc., Form 8-K, Item 8.01 (filed April 2025)	`https://www.sec.gov/Archives/edgar/data/927066/000119312525079593/d948299d8k.htm`	3 Nov 2026	Confirmed
9	Episource, notice letter (California AG filing sb24-612836)	https://oag.ca.gov/ecrime/databreach/reports/sb24-612836	3 Nov 2026	Confirmed
10	Conduent Business Services, notice letter (California AG filing sb24-622398)	https://oag.ca.gov/ecrime/databreach/reports/sb24-622398	3 Nov 2026	Confirmed
11	DentaQuest, notice letter (California AG filing sb24-626583)	https://oag.ca.gov/ecrime/databreach/reports/sb24-626583	3 Nov 2026	Confirmed
12	Lumexa Imaging, notice letter (California AG filing sb24-623542)	https://oag.ca.gov/ecrime/databreach/reports/sb24-623542	3 Nov 2026	Confirmed
13	FBI, CISA and HHS, AA23-353A, #StopRansomware: ALPHV Blackcat (2023-12-19, updated 2024-02-27)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a	3 Nov 2026	Confirmed
14	FBI, CISA, HHS and MS-ISAC, AA24-131A, #StopRansomware: Black Basta (2024-05-10, revised 2024-11-08)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-131a	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
15	FBI, CISA, MS-ISAC and HHS, AA24-242A, #StopRansomware: RansomHub (2024-08-29)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-242a	3 Nov 2026	Confirmed
16	FBI, CISA and HHS, AA25-071A, #StopRansomware: Medusa (2025-03-12, updated 2026-08-18)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-071a	3 Nov 2026	Confirmed
17	FBI, CISA, HHS and MS-ISAC, AA25-203A, #StopRansomware: Interlock (2025-07-22)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-203a	3 Nov 2026	Confirmed
18	CISA, FBI and MS-ISAC, AA23-319A, #StopRansomware: Rhysida (2023-11-15, revised 2025-04-30)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-319a	3 Nov 2026	Confirmed
19	CISA, FBI, MS-ISAC and partner nations, AA23-165A, Understanding LockBit (2023-06-14)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a	3 Nov 2026	Confirmed
20	FBI, CISA, DC3, HHS, Europol EC3 and partners, AA24-109A, #StopRansomware: Akira (2024-04-18, updated 2025-11-13)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a	3 Nov 2026	Confirmed
21	CISA and FBI, AA23-061A, #StopRansomware: Royal / BlackSuit (updated 2024-08-07 and 2024-08-27)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-061a	3 Nov 2026	Confirmed
22	FBI, CISA and partners, AA23-320A, Scattered Spider (2023-11-16, updated 2025-07-29)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a	3 Nov 2026	Confirmed
23	FBI, CISA and Treasury, AA22-187A, North Korean state-sponsored actors use Maui ransomware against HPH (2022-07-06)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-187a	3 Nov 2026	Confirmed
24	FBI and partners, AA24-207A, North Korea cyber group conducts global espionage campaign (2024-07-25)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-207a	3 Nov 2026	Confirmed
25	FBI, CISA and DC3, AA24-241A, Iran-based cyber actors enabling ransomware attacks (2024-08-28)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-241a	3 Nov 2026	Confirmed
26	CISA, FBI and MS-ISAC, AA24-060A, #StopRansomware: Phobos (2024-02-29)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-060a	3 Nov 2026	Confirmed
27	FBI, CISA and ASD's ACSC, AA23-352A, #StopRansomware: Play (December 2023, updated 2025-06-04)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-352a	3 Nov 2026	Confirmed
28	CISA and FBI, AA23-158A, CL0P ransomware gang exploits CVE-2023-34362 MOVEit vulnerability (June 2023)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a	3 Nov 2026	Confirmed
29	CISA, FBI and MS-ISAC, AA25-050A, #StopRansomware: Ghost (Cring) (2025-02-19)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-050a	3 Nov 2026	Confirmed
30	CISA, FBI and HHS, AA22-294A, #StopRansomware: Daixin Team (2022-10-21)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-294a	3 Nov 2026	Confirmed
31	FBI Most Wanted, Rim Jong Hyok	`https://www.fbi.gov/wanted/cyber/rim-jong-hyok`	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
32	Rewards for Justice, Rim Jong Hyok	https://rewardsforjustice.net/rewards/rim-jong-hyok/	3 Nov 2026	Confirmed
33	UK National Crime Agency, LockBit leader unmasked and sanctioned (2024-05-07)	https://www.nationalcrimeagency.gov.uk/news/lockbit-leader-unmasked-and-sanctioned	3 Nov 2026	Confirmed
34	UnitedHealth Group, updates on Change Healthcare cyberattack (2024-04-22)	https://www.unitedhealthgroup.com/newsroom/2024/2024-04-22-uhg-updates-on-change-healthcare-cyberattack.html	3 Nov 2026	Confirmed
35	Microsoft Threat Intelligence, Storm-0501: ransomware attacks expanding to hybrid cloud environments (2024-09-26)	https://www.microsoft.com/en-us/security/blog/2024/09/26/storm-0501-ransomware-attacks-expanding-to-hybrid-cloud-environments/	3 Nov 2026	Confirmed
36	Microsoft Security Insider, US healthcare at risk: strengthening resiliency against ransomware attacks (undated)	https://www.microsoft.com/en-us/security/security-insider/threat-landscape/us-healthcare-at-risk-strengthening-resiliency-against-ransomware-attacks	3 Nov 2026	Confirmed (Microsoft's own findings); Reported (survey figures it relays)
37	FBI Internet Crime Complaint Center, 2024 Internet Crime Report	https://www.ic3.gov/AnnualReport/Reports/2024_IC3Report.pdf	3 Nov 2026	Confirmed
38	CISA, Contec CMS8000 contains a backdoor (2025-01-30, revised 2025-02-13)	https://www.cisa.gov/resources-tools/resources/contec-cms8000-contains-backdoor	3 Nov 2026	Confirmed
39	FDA, cybersecurity vulnerabilities with certain patient monitors from Contec and Epsimed: safety communication (2025-01-30, updated 2025-07-02)	https://www.fda.gov/medical-devices/safety-communications/cybersecurity-vulnerabilities-certain-patient-monitors-contec-and-epsimed-fda-safety-communication	3 Nov 2026	Confirmed
40	MITRE ATT&CK, software S1068 BlackCat	https://attack.mitre.org/software/S1068/	3 Nov 2026	Confirmed
41	MITRE ATT&CK, software S1212 RansomHub	https://attack.mitre.org/software/S1212/	3 Nov 2026	Confirmed
42	MITRE ATT&CK, software S1070 Black Basta	https://attack.mitre.org/software/S1070/	3 Nov 2026	Confirmed
43	MITRE ATT&CK, software S1242 Qilin (modified 2026-04-23)	https://attack.mitre.org/software/S1242/	3 Nov 2026	Confirmed
44	MITRE ATT&CK, group G1050 Water Galura	https://attack.mitre.org/groups/G1050/	3 Nov 2026	Confirmed
45	MITRE ATT&CK, group G0138 Andariel (version 2.0, modified 2026-07-31)	https://attack.mitre.org/groups/G0138/	3 Nov 2026	Confirmed
46	MITRE ATT&CK, group G1051 Medusa Group	https://attack.mitre.org/groups/G1051/	3 Nov 2026	Confirmed
47	MITRE ATT&CK, group G1032 INC Ransom	https://attack.mitre.org/groups/G1032/	3 Nov 2026	Confirmed
48	MITRE ATT&CK, group G1053 Storm-0501	https://attack.mitre.org/groups/G1053/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
49	MITRE ATT&CK, group G0071 Orangeworm	https://attack.mitre.org/groups/G0071/	3 Nov 2026	Confirmed
50	HHS, Healthcare and Public Health Cybersecurity Performance Goals	https://hhscyber.hhs.gov/cybersecurity-performance-goals.html	3 Nov 2026	Confirmed
51	CISA, Healthcare and Public Health cybersecurity toolkit	https://www.cisa.gov/topics/cybersecurity-best-practices/healthcare	3 Nov 2026	Confirmed
52	HHS, Hospital Cyber Resiliency Initiative Landscape Analysis (2023)	https://hhscyber.hhs.gov/Documents/HICP/HHS-hospital-resiliency-analysis.pdf	3 Nov 2026	Confirmed
53	Federal Register, HIPAA Security Rule to Strengthen the Cybersecurity of Electronic Protected Health Information, document 2024-30983 (API record)	https://www.federalregister.gov/api/v1/documents/2024-30983.json	3 Nov 2026	Confirmed
54	HHS, HIPAA Security Rule NPRM fact sheet	`https://www.hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm/factsheet/index.html`	3 Nov 2026	Confirmed
55	Reginfo.gov, Spring 2025 Unified Agenda, RIN 0945-AA22	https://www.reginfo.gov/public/do/eAgendaViewRule?pubId=202504&RIN=0945-AA22	3 Nov 2026	Confirmed
56	Reginfo.gov, current Unified Agenda (pubId 202510), RIN 0945-AA22, XML export	http://www.reginfo.gov/public/do/eAgendaViewRule?pubId=202510&RIN=0945-AA22&operation=OPERATION_EXPORT_XML	3 Nov 2026	Confirmed
57	HHS 405(d), Health Industry Cybersecurity Practices (HICP) 2023 Edition	https://hhscyber.hhs.gov/Documents/HICP/HICP-Main-508.pdf	3 Nov 2026	Confirmed
58	405d.hhs.gov (redirects to the HHS Cyber Gateway)	https://405d.hhs.gov/	3 Nov 2026	Confirmed
59	Public Law 116-321 (H.R. 7898), 2021-01-05	https://www.govinfo.gov/content/pkg/PLAW-116publ321/html/PLAW-116publ321.htm	3 Nov 2026	Confirmed
60	CISA, Mitigation Guide: Healthcare and Public Health (HPH) Sector (2023-11-17)	https://www.cisa.gov/resources-tools/resources/mitigation-guide-healthcare-and-public-health-hph-sector	3 Nov 2026	Confirmed
61	CISA, HPH Sector Mitigation Guide, PDF	https://www.cisa.gov/sites/default/files/2023-12/HPH-Sector-Mitigation-Guide-TLP-CLEAR._508c.pdf	3 Nov 2026	Confirmed
62	CISA, Healthcare and Public Health Sector page	https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/healthcare-and-public-health-sector	3 Nov 2026	Confirmed
63	HHS OCR, HIPAA resolution agreements and civil money penalties	`https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/index.html`	3 Nov 2026	Confirmed
64	HHS OCR, resolution agreement and corrective action plan, Lehigh Valley Health Network	`https://www.hhs.gov/sites/default/files/ocr-ra-cap-lvhn.pdf`	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
65	HHS OCR, resolution agreement with OSF HealthCare System	https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/ra-cap-with-osf-healthcare-system/index.html	3 Nov 2026	Confirmed
66	HHS OCR, resolution agreement and corrective action plan, Ambry Genetics	https://www.hhs.gov/sites/default/files/ocr-ra-cap-ambry-genetics-corporation.pdf	3 Nov 2026	Confirmed
67	HHS OCR, HIPAA agreement with Comstar	https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/hhs-hipaa-agreement-comstar/index.html	3 Nov 2026	Confirmed
68	HHS, HHS imposes $1,500,000 penalty against Warby Parker (2025-02-20)	https://www.hhs.gov/about/news/2025/02/20/hhs-imposes-1500000-penalty-against-warby-parker-hipaa-hacking.html	3 Nov 2026	Confirmed
69	HHS OCR, Change Healthcare cybersecurity incident frequently asked questions	https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html	3 Nov 2026	Confirmed
70	HHS, HIPAA newsroom	https://www.hhs.gov/hipaa/newsroom/index.html	3 Nov 2026	Confirmed
71	Federal Register, FTC Health Breach Notification Rule, document 2024-10855 (API record)	https://www.federalregister.gov/api/v1/documents/2024-10855.json	3 Nov 2026	Confirmed
72	New York State Department of Health, 10 NYCRR 405.46, hospital cybersecurity requirements	https://regs.health.ny.gov/content/section-40546-hospital-cybersecurity-requirements	3 Nov 2026	Confirmed
73	Nebraska Attorney General, lawsuit against Change Healthcare (2024-12-16)	https://ago.nebraska.gov/news/attorney-general-mike-hilgers-files-lawsuit-against-change-healthcare-critical-failures	3 Nov 2026	Confirmed
74	Nebraska Attorney General, court allows case against Change Healthcare to proceed (2025-11-13)	https://ago.nebraska.gov/news/court-allows-attorney-general-hilgers-case-against-change-healthcare-proceed-citing-impact	3 Nov 2026	Confirmed
75	Nebraska Attorney General, multistate settlement with Inmediata (2023-10-17)	https://ago.nebraska.gov/news/attorney-general-hilgers-announces-multistate-settlement-healthcare-clearinghouse-inmediata	3 Nov 2026	Confirmed
76	Nebraska Attorney General, multistate settlement with Labcorp over the AMCA breach (2026-09-24)	https://ago.nebraska.gov/news/attorney-general-mike-hilgers-announces-multistate-settlement-labcorp-over-american-medical	3 Nov 2026	Confirmed
77	S.5218, Health Infrastructure Security and Accountability Act of 2024 (introduced text)	https://www.govinfo.gov/content/pkg/BILLS-118s5218is/html/BILLS-118s5218is.htm	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
78	S.5390, Health Care Cybersecurity and Resiliency Act of 2024 (introduced text)	https://www.govinfo.gov/content/pkg/BILLS-118s5390is/html/BILLS-118s5390is.htm	3 Nov 2026	Confirmed
79	S.3315, Health Care Cybersecurity and Resiliency Act of 2025 (introduced text)	https://www.govinfo.gov/content/pkg/BILLS-119s3315is/html/BILLS-119s3315is.htm	3 Nov 2026	Confirmed
80	S.1851, Healthcare Cybersecurity Act of 2025 (introduced text)	https://www.govinfo.gov/content/pkg/BILLS-119s1851is/html/BILLS-119s1851is.htm	3 Nov 2026	Confirmed
81	Congress.gov API, bill record for S.5218 (118th Congress)	`https://api.congress.gov/v3/bill/118/s/5218`	3 Nov 2026	Confirmed
82	CISA, Known Exploited Vulnerabilities catalog, JSON feed (catalog version 2026.11.03)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	3 Nov 2026	Confirmed
83	TeamStarWolf library data and generated pages: `data/attack/` (groups, software, technique profiles, superseded_by, group and software to technique, technique to D3FEND), `data/weaknesses/`, `mitre/` and `scripts/validate_navigator.py`	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	3 Nov 2026	Confirmed
84	Kettering Health, Notice of privacy incident (unauthorized access between 9 April 2025 and 20 May 2025)	https://ketteringhealth.org/patients-visitors/policies-legal-disclaimers/notice-of-privacy-incident/	3 Nov 2026	Confirmed

Not opened, so not cited as sources: the NHS England statements on Synnovis and the HHS HC3 Qilin, Rhysida and help-desk social-engineering profiles (they carry the Qilin attribution for Synnovis); the Ascension, Yale New Haven and Lurie Children's own incident pages; the Justice Department release on Rim Jong Hyok; the HHS December 2023 concept paper PDF; and the surveys the Microsoft page relays [36].

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Healthcare Security Reference
- Ransomware Defense Reference, Respond to Ransomware and Run a Ransomware Tabletop
- Threat Actors

- Malware Families
- Notable Incidents
- CVE Reference
- ATT&CK Software Reference
- MITRE pages: groups G0138 Andariel, G1036 Moonstone Sleet, G0117 Fox Kitten, G1024 Akira, G1040 Play, G1051 Medusa Group, G1015 Scattered Spider, G1032 INC Ransom, G1050 Water Galura, G1053 Storm-0501, G0092 TA505, G0071 Orangeworm; software S1068 BlackCat, S1070 Black Basta, S1212 RansomHub, S1199 LockBit 2.0, S1202 LockBit 3.0, S1129 Akira, S1194 Akira _v2, S1244 Medusa Ransomware, S1242 Qilin, S1162 Playcrypt, S1139 INC Ransomware, S1247 Embargo, S1073 Royal, S0611 Clop, S0236 Kwampirs; and the technique pages linked in Part 6.2
- CWE Reference, CAPEC Reference, D3FEND Reference
- Other studies: The Change Healthcare Attack of 2024, The Cl0p MOVEit Breach, Log4Shell, APT41: The Public Record, Operation Exchange Marauder, Iran-Attributed Threat Actors: The Public Record, Other State-Linked Threat Actors: The Public Record, Russia-Attributed Threat Actors: The Public Record, China-Attributed Threat Actors: The Public Record, North Korea-Attributed Threat Actors: The Public Record
- The Team Star Wolf Intelligence Hub for the live KEV ledger
- Navigator layers
- All case studies